网络空间安全技术
CH1-CH8 期末复习资料

CH1 网络空间安全概述

本章必背关键词

CIA；系统复杂性；对手威胁；自然破坏；人是薄弱环节；技术层面与管理层面；安全意识；隐蔽性；趋利性；木桶原理。

重点知识与参考答案

重点 1：信息安全问题的根源【填空/判断/简答易考】

参考答案：不能只把安全问题归因于“有黑客、有漏洞、有病毒”。真正的原因包括内因和外因：内因是系统越来越复杂，工作计算机、移动介质、内网其它系统、Internet、其它单位网络、无线网络、远程用户、运维环境等都会扩大暴露面；外因包括对手威胁和自然破坏；人的意识与操作习惯又会成为薄弱环节。

易考提醒：简答题直接写：信息安全问题源于系统复杂性增强、对手威胁、自然破坏和人员因素共同作用，因此安全建设不能只靠某一种产品。

重点 2：对手威胁的层次【选择/简答易考】

参考答案：外部对手可分为国家安全威胁、共同威胁和局部威胁。信息战士可能追求战略优势、制造混乱或目标破坏；情报机构收集政治、军事、经济情报；恐怖分子、商业间谍、犯罪团伙、社会型黑客、娱乐型黑客则具有不同动机。

易考提醒：遇到场景题时，先判断攻击动机：政治军事目标多偏国家安全威胁，竞争优势多偏商业间谍，经济报复和获利多偏犯罪团伙。

重点 3：“人是最薄弱环节”【判断/简答/应用易考】

参考答案：“人是最薄弱环节”的含义是：即使拥有防火墙、入侵检测、生物鉴别设备等技术，只要员工缺乏安全意识，被电话诱导或社会工程欺骗，仍可能导致安全失败。

易考提醒：应用题出现“技术很强但仍泄密”，要从人员教育、管理约束、操作流程和社会工程防范展开。

重点 4：信息安全发展阶段【填空/选择易考】

参考答案：信息安全随通信而产生。早期斯巴达人使用圆柱形棒进行军事加解密；20 世纪 40-70 年代通信安全主要依靠密码技术解决通信保密和内容篡改；70-90 年代后计算机和网络推动信息系统安全发展。

易考提醒：选择题常考“哪个阶段关注通信保密”“哪个阶段关注存储、处理、传输中的安全”。

重点 5：信息安全的 CIA 目标【填空/选择/判断易考】

参考答案：CIA 是信息安全最基础的目标：Confidentiality 机密性、Integrity 完整性、Availability 可用性。机密性强调不被非授权泄漏和使用；完整性强调不被篡改和破坏；可用性强调授权用户或程序能及时、正常使用信息。

易考提醒：填空题要写全中文与英文；判断题常把“完整性”写成“保密不泄露”，要能纠错。

重点 6：信息安全的两个层面【选择/简答易考】

参考答案：信息安全可从技术层面和管理层面理解。技术层面主要防止外部用户非法入侵；管理层面强调内部员工教育和管理。两者不是替代关系，而是共同作用。

易考提醒：简答题不要只写设备清单，要写“技术控制+人员管理+制度执行”。

重点 7：信息安全的本质【填空/简答易考】

参考答案：本质上，信息安全要保护系统的硬件、软件、数据；防止系统和数据遭受破坏、更改、泄露；保证系统连续、可靠、正常运行，服务不中断。

易考提醒：可按“保护什么、防止什么、保证什么”三句组织答案。

重点 8：广义信息安全属性【选择/填空易考】

参考答案：广义上讲，信息安全涉及机密性、完整性、可用性、真实性、可控性等相关技术和理论。这里比 CIA 更宽，加入真实性、可控性等属性。

易考提醒：选择题问“广义信息安全包括哪些属性”时，不要只选 CIA。

重点 9：如何保障信息安全【简答/应用易考】

参考答案：保障信息安全可以从四个方向展开：信息依赖信息技术系统，需要技术控制；信息系统由人建设、使用和维护，需要管理约束；今天安全不代表明天安全，需要贯穿生命周期的工程过程；安全对抗最终是人员知识、技能和素质的对抗，需要人才队伍。

易考提醒：应用题可直接用“四点法”：技术措施、管理制度、生命周期工程、人才与意识建设。

重点 10：我国信息化与安全形势【填空/判断易考】

参考答案：我国信息化建设起步于 20 世纪 80 年代，2000 年后取得长足进步；同时要认识到我国网络空间安全生态环境“不乐观”，并列举网民规模、恶意程序、漏洞、数据泄露等问题。

易考提醒：判断题可能说“信息化发展快，所以安全形势乐观”，这是错误的。

重点 11：网络空间安全趋势：隐蔽性【判断/简答易考】

参考答案：隐蔽性是网络安全的重要特点。很多病毒、流氓软件或攻击并不会立即被发现，用户往往回忆不出何时“中招”，损失可能在不知不觉中扩大。

易考提醒：简答时要说明“看不见摸不着、发现滞后、损失隐蔽”，并引出监测、预警和持续防护的必要性。

重点 12：网络空间安全趋势：趋利性【填空/选择易考】

参考答案：过去为了炫耀能力的黑客少了，为非法取得政治、经济利益的人越来越多。攻击动机从“好玩、挑战”转向利益驱动。

易考提醒：选择题可通过攻击目的区分趋利性：勒索、窃取情报、竞争优势、政治影响都属于利益导向。

重点 13：新应用带来的新风险【选择/简答易考】

参考答案：人工智能、大数据、云计算、系统复杂度、3G/4G/5G、物联网、三网合一、Web2.0、微博、人肉搜索、个人信息泄露等都会带来新的安全问题。需要注意的是 A/B/C 很时髦，但有巨大安全风险。

易考提醒：简答题可直接写“应用越广、数据越集中、网络越融合，风险越集中且影响越大”。

重点 14：网络安全受到高度重视【填空/简答易考】

参考答案：2003 年中办国办文件首次把信息安全提高到促进经济发展、维护社会稳定、保障国家安全、加强精神文明建设的高度；后续国家层面强调“没有网络安全就没有国家安全”。

易考提醒：填空题考年份或表述；简答题可联系国家安全、发展、群众工作生活。

重点 15：《网络安全法》的课堂扩展要点【选择/简答易考】

参考答案：《网络安全法》的若干要点包括：明确网络空间主权原则，明确网络产品和服务提供者安全义务，明确网络运营者安全义务，完善个人信息保护规则，建立关键信息基础设施安全保护制度，并确立重要数据跨境传输规则。

易考提醒：简答题不要展开课外条文，按主要包括的六点概括即可。

重点 16：安全故事的启示【简答/应用易考】

参考答案：温水煮青蛙强调居安思危和风险评估；冰山理论强调看到事故背后更多隐患；墨菲定律强调不能侥幸；名医启示强调防患于未然；木桶原理强调短板决定整体安全。

易考提醒：应用题出现“只重技术忽略管理/人员”，可用木桶原理说明整体安全取决于短板。

高频简答/应用题参考答案

问法 1：为什么不能把信息安全问题简单归因于“有黑客/有病毒/有漏洞”？

参考答案：这些只是表层原因，根源在于系统复杂性增强、外部对手威胁、自然破坏和人员因素共同作用。系统复杂性使攻击面扩大，对手威胁使攻击具有目的性，自然破坏会造成不可控影响，而人又是最薄弱环节。因此治理安全问题要从技术控制、管理约束、生命周期工程和人才意识建设四方面入手。

问法 2：什么是信息安全？

参考答案：先给总定义：信息本身的机密性、完整性和可用性的保持，即防止未经授权使用信息、防止非法修改和破坏、确保及时可靠使用。再分别解释：机密性是不让不该知道的人知道；完整性是不让信息被篡改或破坏；可用性是让授权用户或程序及时正常使用。最后可补充广义信息安全还涉及真实性、可控性等。

问法 3：如何保障信息安全？

参考答案：可以写四点：第一，信息依赖信息技术系统存在，要在技术层面部署控制措施；第二，系统由人建设、使用和维护，要通过管理制度和教育约束人；第三，今天安全不代表明天安全，要把安全工程贯穿系统生命周期；第四，安全对抗归根结底是人员知识、技能和素质对抗，要建设高素质人才队伍。

问法 4：结合木桶原理说明安全建设为什么不能只重视技术。

参考答案：木桶容量取决于最短木板，信息安全整体水平也取决于最薄弱环节。即使部署防火墙、入侵检测和访问控制，若员工随意使用 U 盘、服务器不锁屏、口令管理松散，核心数据仍可能泄露。因此应用题卷面要写“技术、管理、人员、制度”共同构成整体安全，任何短板都会限制最终安全水平。

问法 5：网络空间安全趋势如何理解？

参考答案：直接围绕隐蔽性和趋利性展开。隐蔽性指攻击常在不知不觉中发生，用户可能无法回忆何时中招，因此需要持续监测和预警。趋利性指攻击动机从炫耀能力转向非法政治、经济利益获取。再补充新应用如 AI、大数据、云计算、物联网、5G、Web2.0 等会带来新的安全问题。

问法 6：国家为什么高度重视网络安全？

参考答案：可从国家安全、经济发展、社会稳定和人民生活四方面回答。网络安全和信息化是事关国家安全、国家发展、广大人民群众工作生活的重大战略问题，并强调“没有网络安全就没有国家安全，没有信息化就没有现代化”。因此网络安全不只是技术部门问题，而是国家治理和发展问题。

本章应用题答题框架

- 解释信息安全问题：先写系统复杂性与外部威胁，再写人的薄弱环节，最后说明需要技术、管理、工程、人才共同保障。
- 解释安全目标：先写 CIA，再分别解释机密性、完整性、可用性，最后结合题目说明破坏了哪一项。

CH2 信息安全风险管理与国产化替代

本章必背关键词

风险管理；PDCA；资产；威胁源；威胁；脆弱性；控制措施；可能性；影响；残余风险；风险评估；风险处理；ALE；ROSI；国产化替代；信创。

重点知识与参考答案

重点 1：风险管理的基本含义【填空/简答易考】

参考答案：风险管理是在肯定有风险的环境中，把风险减至最低的管理过程，包括对风险的量度、评估和应变策略。理想的风险管理会先处理最大损失、最可能发生的风险，再处理相对较低的风险。

易考提醒：简答时要写“识别风险、评估风险、按优先级处理风险、把风险控制在可接受水平”。

重点 2：网络安全为什么需要风险管理【简答/应用易考】

参考答案：主要包括典型问题：安全投资逐年增加但看不到收益，按国家或行业要求做了安全仍出事，有限资金不知道优先投哪里，CIO 无法预见系统会出什么事。根源在于没有按风险优先级规划，没有突出控制高风险，没有残余风险清单。

易考提醒：应用题遇到“经费有限如何建设安全”，应答“以风险评估结果排序，优先控制高风险而非平均撒钱”。

重点 3：风险管理的目标【填空/判断易考】

参考答案：好的风险管理使机构以最具成本效益的方式运行，并使已知风险维持在可接受水平；它通过一致、条理清晰的方式组织有限资源并确定优先级，而不是解决所有可能风险。

易考提醒：判断题若说“风险管理目标是消灭全部风险”，应判错。

重点 4：PDCA 与持续管理【判断/简答易考】

参考答案：风险管理是持续的 PDCA 管理过程。安全不是一次检查、一次整改就结束；系统环境、威胁、漏洞、资产价值和业务需求都可能变化。

易考提醒：简答题可直接写“计划、实施、检查、改进形成闭环，风险管理要持续而非一次性”。

重点 5：前瞻性与反应性风险管理【选择/简答易考】

参考答案：正确的风险管理方法包括评估风险、实施风险决策、风险控制、评定有效性，这是前瞻性风险管理；反应性风险管理包括保护人身安全、遏制损害、评估损害、确定损害部位、修复、审查响应过程并更新策略。两者结合才是最佳实践。

易考提醒：可用“流感接种疫苗+感染后治疗”的类比：预防和响应都需要。

重点 6：风险术语：资产【填空/选择易考】

参考答案：资产是任何对组织有价值的东西，是要保护的对象。资产可以是物理的、逻辑的、硬件的、软件的、有形的、无形的、静态的、动态的、技术的或管理的。

易考提醒：选择题给“品牌、名誉、业务目标、人员”时也可能属于资产，不要只理解为设备。

重点 7：风险术语：威胁源与威胁【填空/选择易考】

参考答案：威胁是可能导致信息安全事故和组织资产损失的活动，例子包括操作失误、滥用授权、行为抵赖、身份假冒、口令攻击、密钥分析、漏洞利用、拒绝服务、窃取数据、物理破坏、社会工程。威胁源采取恰当威胁方式才可能引发风险。

易考提醒：场景题先找“谁在做/什么自然因素”是威胁源，再找“做了什么”是威胁方式。

重点 8：风险术语：脆弱性【填空/判断易考】

参考答案：脆弱性是与信息资产有关的弱点或安全隐患，是造成风险的内因。系统代码缺陷、安全配置错误、操作流程缺陷、维护人员安全意识不足都属于脆弱性。脆弱性本身不直接造成危害，但在条件满足时会被威胁源利用。

易考提醒：判断题常把“脆弱性本身就是损失”混淆，应指出它需要被威胁利用才形成风险。

重点 9：风险术语：控制措施【选择/简答易考】

参考答案：控制措施是根据安全需求部署，用来防范威胁、降低风险的措施。例子包括防火墙、入侵检测、审计系统、测试环节、操作审批环节、应急体系、终端 U 盘管理制度等。

易考提醒：应用题要求“给措施”时，要能从技术、流程、制度、应急等角度写。

重点 10：风险术语：可能性与影响【计算/判断易考】

参考答案：可能性是威胁源利用脆弱性造成不良后果的可能程度；影响是造成不良后果的程度大小。一个漏洞在互联网公开且有工具，可能性大；同一设备用于骨干路由或企业内部路由，影响大小不同。

易考提醒：计算题和矩阵题先区分“发生概率/频率”与“损失程度”，不要混为资产价值。

重点 11：风险的构成关系【简答/应用易考】

参考答案：风险关系可概括为：威胁源采取威胁方式，利用脆弱性，破坏资产，造成不良影响；控制措施对风险起控制作用。风险通常只考虑对组织有负面影响的事件。

易考提醒：应用题可按“五方面”分析：威胁源、威胁行为、脆弱性、资产、影响。

重点 12：残余风险【填空/判断/简答易考】

参考答案：残余风险是采取安全措施后仍可能存在的风险。有些残余风险是在综合考虑安全成本与效益后不去控制的风险，但它仍应被密切监视，未来可能诱发新的安全事件。

易考提醒：判断题若说“接受残余风险就是不管”，应判错；答题要写“可接受但需监控”。

重点 13：风险评估的含义【填空/简答易考】

参考答案：风险评估是从风险管理角度，系统分析信息系统面临的威胁及脆弱性，评估安全事件发生后可能造成的危害程度，并提出有针对性的防护对策和整改措施，为把风险控制在可接受水平提供依据。

易考提醒：简答题卷面要写“分析威胁、脆弱性、危害程度，提出对策”。

重点 14：风险评估与风险管理的区别【选择/简答易考】

参考答案：风险管理目标是把风险降低到可接受水平，周期包括风险评估、风险决策、风险控制等阶段，是持续过程；风险评估目标是确定面临的风险并排优先级，是风险管理中的单个阶段，按需要开展。

易考提醒：比较题直接按“目标、周期、计划/持续性”三栏写。

重点 15：风险管理六项工作内容【填空/简答易考】

参考答案：GB/Z 24364 框架包括四个阶段、两个贯穿：建立背景、风险评估、风险处理、批准监督，以及贯穿的监控审查、沟通咨询。

易考提醒：填空题常考顺序；简答题需说明监控审查和沟通咨询贯穿全过程。

重点 16：建立背景【简答易考】

参考答案：建立背景是风险管理第一步，要确定风险管理对象和范围，做好准备，调查信息系统业务目标、技术和管理特点，分析系统体系结构、关键要素、安全要求和安全环境。

易考提醒：卷面可写：确定对象、组建团队、制定计划、获得支持、系统调查、系统分析、安全分析。

重点 17：风险评估过程【简答/应用易考】

参考答案：风险评估依靠结果确定后续风险处理和批准监督。过程包括风险分析准备、风险要素识别、风险分析、风险结果判定。重点是发现威胁、脆弱性和控制措施，判断可能性和影响，综合判定风险等级。

易考提醒：应用题若给系统场景，应先识别资产、威胁、脆弱性、已有控制，再判断风险等级。

重点 18：风险处理过程【简答/应用易考】

参考答案：风险处理目的是把风险始终控制在可接受范围内，步骤包括现存风险判断、处理目标确认、处理措施选择、处理措施实施。不可接受的风险要明确控制到何种程度，再选择措施并落实。

易考提醒：答题必须体现“是否可接受-处理到什么程度-选什么措施-如何实施”。

重点 19：四类风险处置方法【选择/简答/应用易考】

参考答案：常用风险处置包括减低风险、转移风险、规避风险、接受风险。减低风险通常首先考虑；转移风险适合低概率但重大影响且第三方可接受的风险；规避风险是不使用面临风险的资产；接受风险是由于实际和经济原因不再进一步处理但持续监控。

易考提醒：场景题要写适用条件：打补丁/安全域是减低，保险/外包是转移，不联网/不处理敏感信息是规避，成本过高且可承受是接受。

重点 20：定性、定量、半定量评估【选择/简答易考】

参考答案：定性评估依据经验、历史教训、政策走向等非量化资料，用高/中/低等描述影响和可能性，主观性强但容易达成一致。定量评估用货币值、概率或频率，能支持成本效益分析但耗时、复杂。半定量在实际工作中常用，用数值化等级度量风险要素。

易考提醒：比较题直接按“表达方式、优点、缺点、适用”作答。

重点 21：ALE 与 ROSI 计算【计算易考】

参考答案：定量风险分析中，资产价值 AV 与暴露系数 EF 相乘得到单一预期损失 SLE；SLE 与年发生率 ARO 相乘得到年度预期损失 ALE。安全投资收益 ROSI=实施控制前 ALE-实施控制后 ALE-年控制成本。

易考提醒：计算题先写公式，再代入；最后解释结果代表控制措施带来的净收益或损失变化。

重点 22：相乘法与矩阵法【计算/选择易考】

参考答案：矩阵法用可能性等级和影响等级查表得 E/H/M/L 风险等级；相乘法把可能性与影响转成数值相乘，再按预设规则判定风险等级。两者都要先确定可能性和影响。

易考提醒：题目给“A 几乎肯定、影响较大”通常查矩阵；给“可能性 3、影响 5”通常相乘得 15。

重点 23：系统生命周期中的风险管理【填空/简答易考】

参考答案：风险管理贯穿信息系统生命周期：规划、设计、实施、运维、废弃。规划阶段明确方针和需求；设计阶段论证方案、选择技术和产品；实施阶段测试、配置、培训、授权；运维阶段安全运行、变更管理、再评估和重新审批；废弃阶段安全报废。

易考提醒：简答题按五阶段列举，每阶段写 1-2 个活动即可。

重点 24：国产化替代的含义与对象【选择/简答易考】

参考答案：国产化替代是对被垄断的国外产品进行替代。 CPU、操作系统、数据库等基础软硬件是自主可控的正面战场，涉及 Wintel 体系替代、高端服务器和数据库对 IOE 的替代。

易考提醒：答题不要泛泛谈爱国或产业新闻，要写主要包括的 CPU、操作系统、数据库/IOE、应用软件等。

重点 25：CPU、操作系统、IOE 和应用软件替代【填空/选择易考】

参考答案：CPU 方面可概括为申威、飞腾、龙芯等；操作系统方面强调国产 Linux 操作系统及普华、深度、中科方德、银河麒麟、中标麒麟、优麒麟等；IOE 指 IBM 服务器、Oracle 数据库、EMC 存储；国产数据库提到达梦、金仓、南大通用、神通；应用软件如 ERP、CRM、OA、MES 等行业解决方案。

易考提醒：选择题常考“IOE 是什么”“替代 Windows 呼声较高的是什么”“国产 CPU 例子”。

重点 26：信创产业【填空/简答易考】

参考答案：信创即信息技术应用创新，它从云计算、软件、硬件、安全等方面推进和提倡行业创新，提升软硬件信息安全管理和技术防护能力。信创发展是国家战略，也是数字化转型和产业链发展的关键。

易考提醒：简答题可直接写“信创围绕云计算、软件、硬件、安全，目标是提升自主可控和安全防护能力”。

高频简答/应用题参考答案

问法 1：为什么风险管理是网络空间安全保障的有效工作方式？

参考答案：答案应说明：组织资源有限，无法同时解决所有可能风险。风险管理通过识别、评估和排序，使最大损失、最可能发生或最不可接受的风险优先处理，从而以成本效益较高的方式运行。它还能形成残余风险清单，为决策者说明投入方向、剩余风险和触发条件，使安全建设从“买设备”转向“按风险决策”。

问法 2：如何完整分析一个安全风险？

参考答案：可以直接按五方面写：威胁源是谁，采取什么威胁行为，利用了什么脆弱性，作用在哪个资产上，会造成什么影响。还要说明已有控制措施是否足够，以及安全事件发生的可能性和影响程度。最后给出风险等级或处置建议。

问法 3：风险评估和风险管理有什么区别？

参考答案：风险评估是风险管理的起点和基础环节，目标是确定系统面临的风险并排出优先级；风险管理则包括建立背景、风险评估、风险处理、批准监督，并贯穿监控审查和沟通咨询，目标是把风险降到可接受水平。风险评估可按需要开展，而风险管理是持续的 PDCA 过程。

问法 4：四种风险处置方法如何选择？

参考答案：减低风险通常首先考虑，用补丁、身份鉴别、安全域、备份、应急响应等降低威胁、脆弱性或影响；转移风险适用于低概率但影响重大、且第三方可接受的风险，如保险或外包；规避风险是在损失不可接受且难以降低时不使用相关资产或不处理敏感信息；接受风险是因成本或现实原因保留风险，但必须持续监控。

问法 5：定性、定量、半定量风险分析如何比较？

参考答案：定性分析使用高、中、低等文字或等级，依赖经验，参与容易但主观性强；定量分析使用金额、概率、频率和公式，可支持成本效益分析，但复杂、耗时、需要数据；半定量把定性等级数值化，如矩阵法、相乘法，实际工作常用。比较题要围绕表达方式、优缺点和适用场景作答。

问法 6：ALE/ROSI 计算题如何写步骤？

参考答案：先写变量：AV 资产价值，EF 暴露系数，ARO 年发生率，SLE 单一预期损失，ALE 年度预期损失。再写公式：SLE=AV×EF，ALE=SLE×ARO=AV×EF×ARO，ROSI=实施控制前 ALE-实施控制后 ALE-年控制成本。最后代入数据，写出风险损失变化或投资是否值得。

问法 7：为什么风险管理要贯穿系统生命周期？

参考答案：系统在规划、设计、实施、运行维护、废弃各阶段都会引入风险。规划阶段要明确方针和安全需求；设计阶段要论证方案和选择技术产品；实施阶段要测试、配置、培训并授权运行；运维阶段要进行变更管理、再评估和重新审批；废弃阶段要安全报废，防止数据和安全功能被破坏。

问法 8：国产化替代答题应写哪些点？

参考答案：先写含义：替代被垄断的国外产品，目标是自主可控和安全可控。再写替代对象：CPU、操作系统、数据库、高端服务器和存储、应用软件等。重点包括国产 CPU 替代 Intel 架构，国产 Linux 替代 Windows，高端数据库服务器对 IOE 替代，应用软件如 ERP、CRM、OA、MES 等逐步替代。最后可写信创从云计算、软件、硬件、安全推进创新。

本章应用题答题框架

- 风险分析题：先列资产、威胁源、威胁、脆弱性、影响，再判断可能性和风险等级。
- 风险处置题：先判断风险是否可接受，再从减低、转移、规避、接受中选方法，并说明成本效益。
- 计算题：SLE=AV×EF，ALE=SLE×ARO，ROSI=控制前 ALE-控制后 ALE-年控制成本。

CH3 信息与网络空间安全保障

本章必背关键词

信息性质；网络空间安全特征；COMSEC；COMPUSEC；INFOSEC；IA；CS；PDR/PDRR/PPDR；IATF；信息系统安全保障模型；ISPP；ISST；等级保护；风险评估；灾难恢复。

重点知识与参考答案

重点 1：信息的概念【填空/选择易考】

参考答案：主要包括香农、维纳、钟义信的观点：香农认为信息是消除不确定性的东西；维纳强调与外部世界交换的内容；钟义信认为信息是事物运动的状态与方式，是事物属性。考试通常不要求大段背诵，但要能识别代表性表述。

易考提醒：选择题可能问“谁提出信息是消除不确定性的东西”，答案是香农。

重点 2：信息的性质【填空/简答/应用易考】

参考答案：信息具有依附性、可伪性、动态性、可处理性、共享性、可传递性、异步性、可交换性。以微信通信举例说明：消息必须依附文字/语音等载体，可以转发共享，可以异步回复，也可能出现假消息或伪造截图。

易考提醒：应用题要求结合微信举例时，逐项对应“载体、变化、复制转发、延迟回复、伪造”。

重点 3：信息的功能与安全任务【简答易考】

参考答案：信息的基本功能在于维持和强化世界的有序性、动态性，社会功能表现为维系社会生存、促进文明进步和自身发展。网络空间安全的任务就是确保信息功能的正确实现。

易考提醒：简答题可直接写“保护信息不是为保护数据本身，而是保证其功能、业务和社会作用正确发挥”。

重点 4：网络空间安全的基本属性【填空/判断易考】

参考答案：网络空间安全仍以信息的机密性、完整性、可用性为核心属性。机密性防泄露，完整性防篡改，可用性保证授权用户及时使用。

易考提醒：判断题若把网络安全仅看成“防黑客进入”，是不完整的。

重点 5：网络空间安全的特征与范畴【选择/简答易考】

参考答案：网络空间安全是系统的安全、动态的安全、无边界的安全、非传统的安全。范畴不仅包括信息技术问题，还包括组织管理问题、社会问题和国家安全问题。

易考提醒：简答题需从“技术系统、人+组织、法制舆论、国家安全”四层展开。

重点 6：安全发展阶段【填空/选择易考】

参考答案：安全发展包括 COMSEC 通信安全、COMPUSEC 计算机安全、INFOSEC 信息系统安全、IA 信息安全保障、CS/IA 网络空间安全/信息安全保障。每一阶段的关注对象从传输数据扩展到计算机系统、信息系统、业务使命和国家安全。

易考提醒：选择题常考缩写与阶段对应。

重点 7：通信安全 COMSEC【填空/选择易考】

参考答案：通信安全主要在 20 世纪 40-70 年代，通过密码技术解决传输过程中的保密和完整性问题。安全威胁包括搭线窃听、密码学分析；安全措施主要是加密。

易考提醒：答题关键词：传输过程、密码技术、保密、内容篡改。

重点 8：计算机安全 COMPUSEC【选择/简答易考】

参考答案：计算机安全在 20 世纪 70-90 年代，关注软件和硬件中授权或未授权用户执行未授权活动造成的后果，主要保护数据处理和存储时的安全。威胁包括非法访问、恶意代码、脆弱口令；措施包括操作系统访问控制。

易考提醒：与通信安全区分：通信安全保护传输，计算机安全关注主机处理与存储。

重点 9：信息系统安全 INFOSEC【选择/简答易考】

参考答案：信息系统安全综合通信安全和计算机安全，重点保护信息在存储、处理和传输中免受非法泄密、转移或破坏。常见威胁包括网络入侵、病毒破坏、信息对抗；措施包括防火墙、防病毒、漏洞扫描、入侵检测、PKI、VPN 等。

易考提醒：简答题可直接写“综合通信与计算机安全，保护信息全生命周期过程”。

重点 10：信息安全保障 IA【简答/判断易考】

参考答案：IA 把信息安全从技术扩展到管理，从静态扩展到动态，通过技术、管理和工程等措施综合融合，形成对信息、信息系统乃至业务使命的保障。威胁不只包括黑客，还包括恐怖分子、信息战、自然灾难、电力中断等。

易考提醒：判断题若说“IA 只是一套防火墙技术”，应判错。

重点 11：网络空间安全 CS【简答/选择易考】

参考答案：2010 年后，网络安全问题上升到国家安全重要程度。网络空间安全概括为从传统防御的信息保障发展到防御、攻击、情报三位一体，包含网络防御 Defense、网络攻击 Offense、网络利用 Exploitation。

易考提醒：简答题卷面要写“国家安全、威慑、防御攻击情报一体”。

重点 12：网络空间安全保障定义【填空/简答易考】

参考答案：网络空间安全保障包括防止信息泄露、修改和破坏；检测入侵并计划部署防御措施；遭受攻击时通过安全措施和容错机制保证机密性、私密性、完整性、抗抵赖性、真实性、可用性和可靠性；修复受破坏的信息和系统。

易考提醒：简答题按“防止-检测/部署-攻击中维持-攻击后修复”四步写。

重点 13：PDR 模型【填空/简答易考】

参考答案：PDR 由 Protection 保护、Detection 检测、Response 响应构成，出发点是任何防护措施都是基于时间的、可能被攻破的。本质是给出攻防时间表，承认漏洞、正视威胁、适度防护、加强检测、落实反应。

易考提醒：简答题要突出“保护、检测、响应”和“时间视角”。

重点 14：PDRR 模型【填空/选择易考】

参考答案：PDRR 是在 PDR 基础上加入 Restore 恢复，强调自动故障恢复能力。保护是基础，检测发现安全漏洞，反应用来对付入侵，恢复是在系统被入侵后采取措施把系统恢复到正常状态。

易考提醒：选择题常问 PDRR 比 PDR 多了哪一项，答案是恢复 Restore。

重点 15：PPDR 模型【简答/应用易考】

参考答案：PPDR 由 Policy 策略、Protection 防护、Detection 检测、Response 响应构成。其基本思想是在统一安全策略指导下，综合运用防火墙、身份鉴别、加密等防护工具，用漏洞评估、入侵检测等检测工具了解系统状态，通过及时响应把系统调整到较安全状态。

易考提醒：应用题可直接写“策略是核心，防护是基础，检测体现动态性，响应把系统调回风险较低状态”。

重点 16：PPDR 时间公式【计算/判断易考】

参考答案：PPDR 数学法则：Pt 为防护时间，Dt 为检测时间，Rt 为反应时间，Et 为暴露时间。如果 Pt > Dt + Rt，系统是安全的；如果 Pt < Dt + Rt，则 Et=(Dt+Rt)-Pt。

易考提醒：计算题先写变量含义，再比较 Pt 与 Dt+Rt；若不安全再算暴露时间。

重点 17：IATF 深度防御【选择/简答易考】

参考答案：IATF 是信息保障技术框架，代表理论是深度防御。它强调人、技术、操作三要素，从本地计算环境、区域边界、网络和基础设施、支撑性基础设施四个技术焦点领域进行多层防护，保障组织任务/业务运作。

易考提醒：选择题可考“IATF 不是 PPDR”，不要把“安全间隙循环”误归给 IATF。

重点 18：IATF 三要素【填空/简答易考】

参考答案：人是信息保障体系的核心，也是最脆弱要素，涉及意识培训、组织管理、技术管理、操作管理等；技术是实现信息保障的重要手段，包括防护、检测、响应、恢复；操作构成主动防御体系，包括风险评估、安全监控、安全审计、跟踪告警、入侵检测、响应恢复。

易考提醒：简答题按“人、技术、操作”分别写作用。

重点 19：IATF 四个技术焦点领域【填空/简答易考】

参考答案：四个领域为本地计算环境、区域边界、网络和基础设施、支撑性基础设施。本地计算环境保护客户机和服务器数据；区域边界控制进出安全域的数据流；网络和基础设施保护传输和可用性；支撑性基础设施提供密钥管理、证书管理、检测响应等。

易考提醒：填空题容易漏“支撑性基础设施”。

重点 20：信息系统安全保障定义【简答易考】

参考答案：信息系统安全保障是在信息系统整个生命周期中，从技术、管理、工程和人员等方面提出安全保障要求，确保保密性、完整性、可用性，降低安全风险到可接受程度，从而保障组织使命实现。

易考提醒：简答题务必出现“生命周期、四要素、CIA、可接受风险、业务使命”。

重点 21：信息系统安全保障模型【选择/简答易考】

参考答案：GB/T 20274.1-2006 模型包含生命周期、保障要素和安全特征三个维度。生命周期包括计划组织、开发采购、实施交付、运行维护、废弃；保障要素包括技术、工程、管理、人员；安全特征包括机密性、完整性、可用性。

易考提醒：选择题常考三维模型的组成。

重点 22：风险、策略与业务使命【简答/判断易考】

参考答案：风险和策略是信息系统安全保障的核心问题，业务使命实现是信息安全保障的根本目的。安全措施不是孤立目的，而是为了保护资产、支撑系统能力、降低风险并保障使命。

易考提醒：判断题“安全保障最终目的只是保护设备”应判错。

重点 23：我国网络空间安全保障体系 【填空/简答易考】

参考答案：我国网络空间安全保障体系包括法律法规与政策环境、组织机构及管理体系、技术与产业支撑平台、基础设施、标准与规范、人才培训教育体系等。

易考提醒：简答题可列六方面，不必展开课外政策。

重点 24：等级保护、风险评估、灾难恢复 【简答/选择易考】

参考答案：等级保护重点保障基础信息网络和关系国家安全、经济命脉、社会稳定的重要信息系统；风险评估是网络空间安全建设的起点和基础，倡导适度安全；灾难恢复是业务连续运作需要，也是综合保障的最后一道防线。

易考提醒：比较题可直接写“等保重基线与等级，风险评估重识别风险，灾难恢复重业务连续”。

重点 25：安全需求、ISPP 与 ISST 【选择/简答易考】

参考答案：安全需求来自风险评估、法规符合性和业务需求。ISPP 从信息系统所有者/用户角度规范化、结构化描述安全保障需求；ISST 从建设方/厂商角度制定信息系统安全保障方案，并根据 ISPP 编制。

易考提醒：选择题常考 ISPP 与 ISST 的角度：ISPP=所有者需求，ISST=建设方方案。

高频简答/应用题参考答案

问法 1：如何理解网络空间安全保障？

参考答案：可写四层：防止信息泄露、修改和破坏；检测入侵行为并计划部署防御措施；在遭受攻击时通过安全措施和容错机制维持机密性、完整性、可用性、真实性、抗抵赖性等；攻击后修复信息和信息系统。与只强调“防止攻击”的信息安全相比，保障更重视检测、响应和修复。

问法 2：PDR、PDRR、PPDR 如何区分？

参考答案：PDR 是保护、检测、响应，强调任何防护都有时间限制，要落实反应；PDRR 在 PDR 基础上加入恢复，强调系统被入侵后的自动故障恢复能力；PPDR 在策略 Policy 指导下组织防护、检测、响应，强调动态循环、控制和对抗，策略是核心，防护是基础，检测体现动态性，响应降低风险。

问法 3：PPDR 计算题怎样作答？

参考答案：先解释变量：Pt 是防护时间，Dt 是检测时间，Rt 是反应时间，Et 是暴露时间。再判断 Pt 与 Dt+Rt 关系：若 Pt>Dt+Rt，说明在防护被突破前已经检测并响应，系统是安全的；若 Pt<Dt+Rt，则暴露时间 Et=(Dt+Rt)-Pt，说明存在未受保护窗口。

问法 4：IATF 深度防御如何作答？

参考答案：先写 IATF 是信息保障技术框架，代表思想为深度防御。再写三要素：人、技术、操作。最后写四个技术焦点领域：本地计算环境、区域边界、网络和基础设施、支撑性基础设施。答题要体现多层、多角度防护，而不是只部署单一设备。

问法 5：信息系统安全保障模型包括什么？

参考答案：答案要围绕三维模型：生命周期、保障要素、安全特征。生命周期包括计划组织、开发采购、实施交付、运行维护、废弃；保障要素包括技术、工程、管理、人员；安全特征包括机密性、完整性、可用性。核心目标是把风险降低到可接受水平，最终保障组织业务使命。

问法 6：ISPP 与 ISST 如何区分？

参考答案：ISPP 是信息系统保护轮廓，从所有者或用户角度，对一类系统的安全保障需求进行规范化、结构化描述，强调需求；ISST 是信息系统安全目标，从建设方或厂商角度，根据信息系统保护轮廓编制安全保障方案，强调实现方案。选择题抓“用户需求”与“建设方案”。

问法 7：我国网络空间安全保障体系可从哪些方面写？

参考答案：可列法律法规与政策环境、组织机构及管理体系、技术与产业支撑平台、基础设施、标准与规范、人才培训教育体系。简答题应写体系化建设，而不是只写某一部法律或某一种技术。

问法 8：等级保护、风险评估、灾难恢复分别解决什么？

参考答案：等级保护强调按照等级要求保护基础信息网络和重要信息系统；风险评估强调识别风险、分析风险、提出整改建议，是安全建设起点和基础；灾难恢复强调在灾难或重大事故后保持业务连续，是综合保障最后一道防线。

本章应用题答题框架

- 模型题：PDR/PDRR/PPDR 先写英文构成，再说明每一环节作用。
- PPDR 计算题：先写 Pt、Dt、Rt，再判断 Pt 是否大于 Dt+Rt，不满足时计算暴露时间 Et。

- 保障题：从技术、管理、工程、人员和生命周期展开，最后落到业务使命。

CH4 网络空间安全技术体系与机制

本章必背关键词

五重保护机制；进不来、拿不走、改不了、看不懂、跑不掉、打不垮；OSI 安全服务；八种安全机制；信息系统安全体系框架；密码；MAC；数字签名；数据完整性。

重点知识与参考答案

重点 1：信息系统安全的目的【填空/简答易考】

参考答案：可用“进不来、拿不走、改不了、看不懂、跑不掉、打不垮”概括安全目的。它们分别对应阻止非法进入、防止数据被窃取、防止篡改、保护机密性、保证行为可追责、维持系统可用。

易考提醒：简答题可把口号展开成安全目标：访问控制、机密性、完整性、抗抵赖、可用性。

重点 2：网络空间安全保护机制的范围【简答易考】

参考答案：网络空间安全保护机制不仅包括计算机技术、网络技术，还包括电磁辐射、环境安全、信息安全管理、法律和心理因素等。安全是综合体系而非单一技术。

易考提醒：应用题若只部署一台设备，应指出还需要管理、法律、人员、物理环境等配合。

重点 3：OSI 安全体系结构中的五种安全服务【填空/选择易考】

参考答案：五种安全服务包括鉴别服务、访问控制服务、数据机密性服务、数据完整性服务、抗抵赖服务。服务的目的在于利用一种或多种安全机制保障信息系统安全或可靠运行。

易考提醒：选择题常考“不属于安全服务”的选项。

重点 4：鉴别服务【填空/判断易考】

参考答案：鉴别服务提供通信中的对等实体鉴别和数据来源鉴别，目的是确认实体或数据来源是否真实。后续访问控制、审计、完整性等服务往往依赖可信身份。

易考提醒：判断题“鉴别等于授权”是错的，鉴别是确认身份，授权是给权限。

重点 5：访问控制服务【简答易考】

参考答案：访问控制服务保护开放系统互连可访问资源，防止非授权使用。它决定主体可以访问哪些资源、执行哪些操作，并可配合报警或审计跟踪。

易考提醒：答题要写“主体、客体、权限、非授权访问控制”。

重点 6：数据机密性服务【填空/选择易考】

参考答案：数据机密性服务保护数据不被非授权泄漏。可包括连接机密性、无连接机密性、选择字段机密性和业务流机密性等。

易考提醒：选择题可通过“防泄露、看不懂”判断为机密性。

重点 7：数据完整性服务【填空/简答易考】

参考答案：数据完整性服务在有连接或无连接情况下对数据进行完整性检验，发现篡改、插入、删除等异常时可进行补救或恢复。

易考提醒：简答题卷面要写“修改、插入、删除、替换可检测”。

重点 8：抗抵赖服务【填空/判断易考】

参考答案：抗抵赖服务通过证据保留防止发送者否认发送、接收者否认收到。发送者产生发送证据，接收者接收后产生交付证据并返回。

易考提醒：判断题“抗抵赖就是加密保密”是错的，核心是行为证据。

重点 9：八种基本安全机制【填空/选择易考】

参考答案：八种基本机制为加密、数字签名、访问控制、数据完整性、鉴别交换、通信业务流填充、路由选择控制、公证。其他机制包括可信功能模块、安全标记、事件检测、安全审计跟踪、安全恢复。

易考提醒：填空题要背全，选择题常把“审计跟踪”放入基本机制中混淆。

重点 10：加密机制【简答/选择易考】

参考答案：加密既能为数据提供机密性，也能为通信业务流提供机密性，还可为其它机制提供补充，可配置在多个协议层次中。对称密钥速度快但有密钥分发问题，公钥体制可用于加密、签名和密钥管理。

易考提醒：简答题可直接写“加密保护看不懂，但不等于自动提供所有安全属性”。

重点 11：数字签名机制【填空/判断易考】

参考答案：数字签名可以完成数据单元签名和对已有签名的验证，必须不可伪造和不可抵赖。RSA 签名可用私钥签名、公钥验证；RSA 也可在一个算法中实现签名和加密。

易考提醒：判断题“数字签名用公钥签名、私钥验证”应判错。

重点 12：访问控制机制与最小特权【简答/应用易考】

参考答案：访问控制机制按实体拥有的访问权限对资源访问进行控制，对非授权或不正当访问应有报警或审计。最小特权原则：用户和代表用户的进程只应拥有完成职责所需的最小权限集合。

易考提醒：应用题给权限设计时，要写“合法主体访问合法客体，权限最小化”。

重点 13：数据完整性机制的分类【填空/简答易考】

参考答案：完整性机制分为通过密码学、通过上下文、通过探测和确认、通过阻止提供完整性。密码学方式包括对称密钥下的密封、非对称密码下的数字签名、冗余数据加密等。

易考提醒：简答题可直接写“四类机制+各自核心”。

重点 14：验证码/附加码的完整性思路【简答易考】

参考答案：发送方根据原信息生成与信息密切相关的验证码，与原信息一起发送；接收方分离消息和验证码，对收到的消息重新计算验证码并比较。如果一致则认为完整，否则认为被篡改。

易考提醒：答题可按“生成-发送-分离-重算-比较-判断”六步写。

重点 15：CRC 校验与完整性保护的局限【判断/简答易考】

参考答案：能检测数据错误的机制不一定能对抗攻击者的篡改。如果攻击者同时修改数据和 CRC，并按公开 CRC 多项式重新计算，接收方仍可能认为匹配。解决思路是结合加密、MAC、数字签名等。

易考提醒：判断题“CRC 能防止恶意篡改”一般应判错。

重点 16：消息认证码 MAC【填空/简答易考】

参考答案：MAC 利用共享秘密密钥和 MAC 产生函数生成鉴别码。接收方用同一密钥和函数重新计算并比较，可确认消息未被更改，也能防止攻击者替换消息后生成正确 MAC。缺点是没有保密作用，且需要共享密钥。

易考提醒：简答题卷面要写“完整性/认证有，保密没有；关键依赖共享密钥”。

重点 17：消息摘要【判断/简答易考】

参考答案：消息摘要用 MD5、SHA-1 等哈希函数产生固定长度摘要，优点是不需要双方共享密钥、有效率高。若攻击者能同时修改消息和摘要，接收方无法判断完整性，因此要与加密或签名结合。

易考提醒：判断题“消息摘要单独即可抵抗同时篡改消息和摘要”是错的。

重点 18：鉴别交换机制【简答易考】

参考答案：鉴别交换机制通过交换信息确认实体身份，可使用密码技术和特定握手协议防止鉴别重放。口令、挑战-应答、生物特征都属于鉴别思路。所有其它安全服务都依赖于鉴别服务。

易考提醒：简答题卷面要写“确认身份、对抗假冒、可防重放”。

重点 19：通信业务流填充机制【选择/简答易考】

参考答案：业务分析，尤其基于流量的业务分析，是攻击通信系统的重要方法。通信业务流填充通过添加填充业务，使攻击者更难从流量大小、频率、时间规律判断真实通信内容或业务关系。

易考提醒：选择题看到“防业务流量分析”，对应通信业务流填充。

重点 20：路由选择控制机制【选择/简答易考】

参考答案：路由选择控制机制针对数据单元的安全性要求提供安全路由选择方法。它不是内容加密，而是通过控制路径来满足安全需求。

易考提醒：选择题要区分“路由选择控制”和“访问控制”。

重点 21：公证机制【填空/简答易考】

参考答案：公证机制通过第三方机构，对通信数据的完整性、原发性、时间和目的地等进行公证。通常结合数字签名、加密等机制来适应公证服务。

易考提醒：简答题关键词：第三方、完整性、原发性、时间、目的地。

重点 22：信息系统安全体系框架【简答易考】

参考答案：完整的信息系统安全体系框架由技术体系、组织机构体系和管理体系共同构建。技术体系包括物理安全、系统安全等；组织机构体系包括机构、岗位、人事；管理体系包括法律管理、制度管理和培训管理。

易考提醒：应用题若问“如何构建体系”，答“技术+组织+管理”，不要只列技术产品。

重点 23：组织机构体系 【填空/简答易考】

参考答案：组织机构体系是信息系统安全的组织保障系统，由机构、岗位、人事三个模块构成。机构设置分决策层、管理层、执行层；岗位负责安全事务；人事机构对在职、待职、离职雇员进行教育、考核和监管。

易考提醒：简答题可直接写“三层机构、岗位职责、人事管理”。

重点 24：管理体系 【简答/判断易考】

参考答案：“管理是信息系统安全的灵魂”“三分技术，七分管理；管理与技术并重”。管理体系包括法律管理、制度管理和培训管理。

易考提醒：判断题“只要技术强就不需要制度和培训”应判错。

重点 25：网络空间安全技术层次 【填空/选择易考】

参考答案：安全防范技术体系可划分为物理层安全、系统层安全、网络层安全、应用层安全、管理层安全。物理层涉及线路、设备、机房、UPS、防灾防干扰；系统层涉及操作系统缺陷、配置、病毒；网络层涉及传输和接入；应用层涉及服务软件与数据；管理层涉及制度、职责、人员角色。

易考提醒：选择题通过场景判断层次，例如机房温湿度属于物理层，操作系统补丁属于系统层。

高频简答/应用题参考答案

问法 1：五种安全服务如何组织答案？

参考答案：先列五种：鉴别、访问控制、数据机密性、数据完整性、抗抵赖。再分别解释：鉴别确认身份或来源；访问控制限制资源使用；机密性防止非授权泄露；完整性防止或发现篡改、插入、删除；抗抵赖保留发送或接收证据。最后说明安全服务通常依赖一种或多种安全机制实现。

问法 2：八种安全机制如何组织答案？

参考答案：先列八种：加密、数字签名、访问控制、数据完整性、鉴别交换、通信业务流填充、路由选择控制、公证。再解释每类核心用途，如加密提供机密性，数字签名提供不可伪造和不可抵赖，业务流填充对抗流量分析，公证依赖第三方提供证据。

问法 3：加密、签名、MAC、摘要的区别如何答？

参考答案：加密主要让数据“看不懂”，保护机密性；数字签名用私钥签名、公钥验证，强调不可伪造、不可抵赖和完整性；MAC 依赖共享秘密密钥验证消息完整性和来源，但没有保密作用；消息摘要用哈希函数产生摘要，效率高，但单独使用时无法防止攻击者同时改消息和摘要。

问法 4：为什么 CRC 不能单独保证抗恶意篡改？

参考答案：CRC 等错误检测码能发现传输错误，但算法公开，攻击者如果同时修改原数据和 CRC，使二者保持匹配，接收方仍可能认为数据完整。因此完整性保护要结合密钥、加密、MAC 或数字签名，使攻击者无法生成合法校验值或签名。

问法 5：数据完整性机制的一般流程是什么？

参考答案：发送方根据原始信息生成附加码或验证码，将原信息和验证码发送；接收方分离消息和验证码，用相同约定函数对收到消息重新计算验证码；若两者一致，认为完整，否则认为被篡改。可按“生成、发送、分离、重算、比较、判断”作答。

问法 6：信息系统安全体系框架如何答？

参考答案：完整框架由技术体系、组织机构体系和管理体系共同构建。技术体系包括物理安全、系统安全、网络安全、应用安全等；组织机构体系包括决策层、管理层、执行层以及岗位和人事管理；管理体系包括法律管理、制度管理、培训管理。答题要体现“管理是灵魂，技术与管理并重”。

问法 7：网络空间安全技术层次如何举例？

参考答案：物理层包括线路、机房、设备、UPS、防灾防干扰；系统层包括操作系统漏洞、配置、病毒；网络层包括网络身份鉴别、访问控制、传输机密性完整性、远程接入、DNS 和路由安全、入侵检测；应用层包括 Web、邮件、DNS 等应用软件和数据安全；管理层包括制度、职责和人员角色。

本章应用题答题框架

- 安全服务题：五种服务要背全，注意鉴别、访问控制、机密性、完整性、抗抵赖的区别。
- 安全机制题：八种机制要背全，注意加密、签名、MAC、摘要、CRC 的作用和局限。
- 体系题：技术体系、组织机构体系、管理体系三部分共同构建。

CH5 鉴别机制与技术

本章必背关键词

鉴别；声称者 P；验证者 V；可信第三方 TP；攻击者；双向/单向鉴别；0-4 级鉴别；口令；PAP；Salt；OTP；质询-应答；生物特征；智能卡；零知识证明。

重点知识与参考答案

重点 1：鉴别的需求与目的 【填空/简答易考】

参考答案：鉴别需求是某一成员提交一个主体的身份并声称它就是那个主体；鉴别目的则是使验证者获得对声称者所声称事实的信任。鉴别确认实体是它所声明的，可以对抗假冒攻击。

易考提醒：简答题写“谁声明、谁验证、目标是让验证者相信身份真实”。

重点 2：鉴别与其他机制的关系 【简答/判断易考】

参考答案：鉴别是最重要的安全服务之一，所有其它安全服务都依赖该服务。访问控制依赖确知身份才能执行；鉴别可与数据完整性结合提供数据起源鉴别；审计机制需要把活动和确知身份关联以支持责任原则。

易考提醒：判断题“访问控制不需要鉴别”应判错。

重点 3：实体鉴别系统组成 【填空/选择易考】

参考答案：实体鉴别系统包括示证者 P/声称者、验证者 V、可信第三方 TP 和攻击者。P 出示证件或证明身份，V 检验证件正确性和合法性，TP 参与调解或提供可信服务，攻击者可能窃听或伪装。

易考提醒：选择题常考 P、V、TP 英文含义。

重点 4：身份鉴别系统要求 【简答易考】

参考答案：主要包括要求：验证者正确识别合法申请者概率极大化；不具有可传递性；攻击者伪装成功概率小到可忽略；计算有效性；通信有效性；秘密参数安全存储；还包括交互识别、第三方实时参与、第三方可信赖、可证明安全性等。

易考提醒：简答题可写前六项作为核心。

重点 5：网络环境下的鉴别需求 【简答易考】

参考答案：网络环境要求唯一身份标识，如 uid、uid@domain、DN；要抗被动威胁，口令不在网上明码传输；还要抵抗阻断、伪造、重放等主动威胁，使网络上传输的鉴别信息不可重用。

易考提醒：简答题关键词：唯一 ID、抗窃听、不明文、抗重放。

重点 6：实现鉴别的三类途径 【填空/选择易考】

参考答案：实现身份鉴别可基于你所知道的（口令、密码）、你所拥有的（身份证、信用卡、钥匙、智能卡、令牌）、你的个人特征（指纹、笔迹、声音、手型、脸型、视网膜、虹膜）。双因素/多因素认证把多类因素结合。

易考提醒：选择题给“指纹+令牌”可判断为多因素认证。

重点 7：按保护等级分类：0 级到 4 级 【填空/选择易考】

参考答案：0 级无保护，申请 AI 直接发送，易泄露和重放；1 级抗泄露但仍易重放；2 级防泄露并防对不同验证者重放；3 级防泄露并防对同一验证者重放；4 级防泄露并防对相同/不同验证者重放。

易考提醒：记忆口诀：0 裸传，1 防泄露，2 防不同 V 重放，3 防同一 V 重放，4 防所有 V 重放。

重点 8：0 级鉴别 【判断/简答易考】

参考答案：0 级鉴别把申请 AI 连同可辨别标识符一起发送，如直接发送口令。它简单，可用于数据源和实体鉴别，但容易暴露鉴别信息，也容易受到重放攻击。

易考提醒：判断题“直接发送口令安全性高”应判错。

重点 9：1 级鉴别 【选择/判断易考】

参考答案：1 级提供防止申请 AI 泄露的保护，实际 AI 不在信道中明文传输，而是用变换函数处理，如传送单向函数变换后的通行字或用秘密密钥加密数字指纹。但由于结果可能被复制，仍易重放。

易考提醒：选择题看到“只防泄露不防重放”选 1 级。

重点 10：2 级与 3 级鉴别 【选择/简答易考】

参考答案：2 级在输入中加入预期验证者，防止把对一个验证者的鉴别信息拿去对另一个验证者重放，但不能防同一验证者重放。3 级加入惟一数，如随机数、时间戳、计数器、密码链，防止对同一验证者重放。

易考提醒：比较题写：2 级靠验证者标识，3 级靠惟一数。

重点 11：4 级鉴别四种方案【填空/简答易考】

参考答案：4 级包括惟一数机制、质询机制、专用加密质询机制、计算响应机制。共同目标是在防泄露的同时对相同和不同验证者的重放都提供保护。

易考提醒：简答题列四种名称即可，不要只写“质询应答”。

重点 12：质询-应答技术【简答/应用易考】

参考答案：验证者发送一个非重复值作为质询，声称者利用申请 AI 和函数计算应答返回。由于每次质询不同，传输的鉴别信息不同，可有效防止口令窃听和重放，但会增加通信开销。

易考提醒：应用题若要求防重放，应优先想到“非重复质询+响应”。

重点 13：口令机制【简答/判断易考】

参考答案：口令机制是最广泛使用的身份鉴别方法，通常保存用户身份信息和口令，选择原则是易记、难猜、抗分析能力强。PAP 通常在通信连接建立阶段进行鉴别，数据传输阶段不进行 PAP 鉴别。

易考提醒：判断题“口令越容易猜越好”错误；答题要写易记与难猜平衡。

重点 14：口令系统的脆弱点【填空/简答易考】

参考答案：口令系统的脆弱点包括外部泄露、口令猜测、线路窃听、危及验证者、重放攻击。不同问题对应不同措施：培训和管理防泄露，限制登录次数和最小长度防猜测，单向函数/加盐/OTP 防窃听和重放。

易考提醒：简答题可按“威胁类型-措施”列表写。

重点 15：Salt 加盐机制【简答/判断易考】

参考答案：加盐是在散列运算时增加随机 Salt 字符串，与口令混合后得到散列值，使字典攻击更困难。它能缓解多台计算机使用相同口令或同一计算机多用户同口令的问题，但不是万能方案。

易考提醒：判断题“加盐后口令绝对安全”应判错。

重点 16：一次性口令 OTP【填空/简答易考】

参考答案：OTP 确保每次认证使用的口令不同，用于对付重放攻击。口令确定方法包括两端共同拥有随机口令串并同步位置、共同使用随机序列生成器并同步初态、使用时间戳并维持同步时钟。

易考提醒：简答题卷面要写“每次不同、需要同步、对付重放”。

重点 17：S/Key 一次性口令【选择/简答易考】

参考答案：S/Key 通过种子 seed、迭代值 M 和散列函数产生一次性口令，验证者验证后更新存储值和迭代次数。其缺陷包括不能防小数攻击，缺乏完整性保护，不能保护鉴别过程免受主动攻击。

易考提醒：选择题问 S/Key 缺陷时，不要写“没有任何缺点”。

重点 18：基于地址的机制【判断/简答易考】

参考答案：基于地址的机制假定声称者可鉴别性基于呼叫源地址，验证者为每个主体维护合法呼叫地址文件。但地址转换、临时环境、转发或重定向会带来问题，单独不能作为可靠鉴别机制，只能作为补充。

易考提醒：判断题“IP 地址可以单独完成强身份鉴别”应判错。

重点 19：生物特征鉴别【选择/简答易考】

参考答案：生物特征基于每个人生理特征唯一性的假设，如指纹、视网膜、声音、虹膜、语音、面部、签名等。指纹识别通过采集、分析、比对模板指纹来认证身份。

易考提醒：选择题可通过“你是什么”判断为生物特征因素。

重点 20：个人令牌与智能卡【简答易考】

参考答案：个人令牌支持“某人拥有某物”，通常与口令或 PIN 结合。智能卡可在与外界通信前完成与终端的认证，加入安全传感器，存储器加密，支持 DES、3DES、RSA 等算法。

易考提醒：应用题出现“卡+PIN+证书签名”，可判为拥有因素结合知识因素。

重点 21：零知识证明三原则【填空/简答易考】

参考答案：零知识证明希望声称者证明自己拥有某种秘密或能力，同时不泄露任何有用信息。三原则为完备性（真的假不了）、合理性/可靠性（假的真不了）、零知识（验证者只知道证明者具备能力，不获得秘密本身）。

易考提醒：简答题必须写三原则，尤其“验证者不能获得其它知识”。

重点 22：洞穴问题【计算/简答易考】

参考答案：洞穴 C 和 D 之间有暗门，知道咒语才能打开。P 先进洞到 C 或 D，V 随机要求 P 从左或右通道出来；重复 n 次。若 P 不知道咒语，每轮猜中的概率是 1/2，n 轮都猜中概率是 1/2^n；16 轮后为 1/65536。

易考提醒：计算题写概率 1/2^n；简答题写“反复随机挑战，不泄露咒语”。

重点 23：采用对称密码的鉴别机制【简答易考】

参考答案：基于对称密码算法的鉴别依靠共享密钥，在质询-应答协议中处理或加密交换信息。设计鉴别和密钥交换协议时核心问题是保密性和时效性，后者用于防消息重放。

易考提醒：简答题写“共享密钥、质询应答、保密性、时效性、抗重放”。

高频简答/应用题参考答案

问法 1：鉴别题怎样答得完整？

参考答案：先写鉴别是确认实体是它所声明的，提供关于身份的保证，用来对抗假冒攻击。再写组成：示证者 P/声称者、验证者 V、可信第三方 TP、攻击者。最后说明鉴别与访问控制、完整性、审计关系密切，访问控制依赖确知身份，审计需要把活动和身份关联。

问法 2：0-4 级鉴别如何区分？

参考答案：按两个问题记：是否防申请 AI 泄露，是否防重放。0 级直接发送无保护；1 级不明文发送申请 AI，防泄露但不防重放；2 级加入预期验证者，防不同验证者重放；3 级加入随机数、时间戳、计数器等惟一数，防同一验证者重放；4 级同时防相同和不同验证者重放。

问法 3：口令安全措施如何分层作答？

参考答案：外部泄露靠教育培训、严格管理、定期改变口令、每人唯一、输入不回显；口令猜测靠限制非法登录次数、实时延迟、最小长度、避免个人特征、修改默认口令；线路窃听靠一次性口令、散列函数、加盐；重放靠随机数、质询应答或 OTP。

问法 4：OTP 为什么能防重放？

参考答案：一次性口令机制保证每次认证使用的口令不同，即使攻击者窃听到一次认证信息，以后重放也会失效。实现方式包括双方共享随机口令串并同步位置、共享随机序列生成器并同步初态、使用时间戳并维持同步时钟。答案要强调“每次不同”和“同步”。

问法 5：质询-应答如何说明？

参考答案：验证者生成一个非重复的质询值发给声称者，声称者把质询和申请 AI 输入约定函数，得到应答返回。验证者验证应答是否正确。因为每次质询都不同，网络上传输的鉴别信息不能直接重放，因此能抵抗窃听后的重放攻击。

问法 6：智能卡鉴别流程如何写？

参考答案：可写：客户端发起登录，服务器要求身份认证；客户端请求读出公钥证书，智能卡要求输入 PIN；PIN 验证通过后读出证书并发给服务器；服务器验证证书有效性后发随机数；客户端用智能卡私钥对随机数签名，服务器用公钥验证签名，验证通过允许登录。

问法 7：零知识证明答题模板是什么？

参考答案：先写目标：证明者证明自己知道秘密或拥有能力，但不泄露秘密本身。再写三原则：完备性、合理性、零知识。最后用洞穴问题说明：验证者随机指定出口，证明者若真知道咒语总能出来；若不知道，每轮只有 1/2 概率猜中，n 轮全中概率 1/2^n。

问法 8：为什么洞穴问题中验证者不能看证明者从哪边进入？

参考答案：如果验证者看见证明者从哪边进入，再要求从另一边出来，录像给第三方看时第三方也可确信证明者知道咒语，这会额外泄露“证明者拥有秘密”这一知识。零知识证明要求验证者除“证明者确实有能力”之外不获得其他可转移知识，因此进入路径不能被验证者掌握。

本章应用题答题框架

- 鉴别等级题：围绕“泄露保护”和“重放保护对象”区分 0-4 级。
- 口令题：按外部泄露、猜测、窃听、危及验证者、重放分别写措施。
- 零知识题：必须写完备性、合理性、零知识，并用洞穴问题说明概率。

CH6 访问控制机制与技术

本章必背关键词

主体；客体；访问；授权；标识；鉴别；访问控制模型；AEF；ADF；ACL；CL；DAC；MAC；BLP；Biba；RBAC；角色继承；互斥；责任分离。

重点知识与参考答案

重点 1：访问控制的概念和目标【填空/简答易考】

参考答案：访问控制是针对越权使用资源的防御措施。目标是防止对计算资源、通信资源、信息资源等进行未授权访问，使资源在授权范围内使用，并决定用户能做什么以及代表用户利益的程序能做什么。

易考提醒：简答题关键词：防未授权、资源、授权范围、用户/进程能做什么。

重点 2：访问控制的作用【选择/判断易考】

参考答案：访问控制直接支持机密性、完整性和可用性。限制读取可以保护机密性，限制修改可以保护完整性，限制资源使用量有助于保证可用性。

易考提醒：判断题“访问控制只与机密性有关”应判错。

重点 3：主体、客体和访问【填空/选择易考】

参考答案：主体是发起者，是主动实体，如用户、程序、进程；客体是被操作对象，是需要保护的资源，如文件、存储介质、程序、进程等；访问是对资源的使用，如读、写、修改、删除。

易考提醒：选择题给“进程访问文件”，进程可作主体，文件作客体。

重点 4：主体与客体关系的相对性【判断/简答易考】

参考答案：主体和客体关系是相对的。一个实体在某个访问中是主体，在另一个访问中可能成为客体。主体可以创建其他主体并控制它们，客体通常提供或驻留信息。

易考提醒：判断题“某实体永远只能是主体或客体”错误。

重点 5：访问三元组【填空/应用易考】

参考答案：访问可描述为三元组(S,A,O)：Subject 主体、Access 访问操作、Object 客体。任何访问控制规则最终都要说明哪个主体对哪个客体执行哪些操作。

易考提醒：应用题列规则时按“主体-操作-客体”写，表达清晰。

重点 6：授权与标识【填空/简答易考】

参考答案：授权规定主体可以对客体执行的操作，如读、写、执行、拒绝访问等。标识是实体身份的计算机表达，主要用于访问控制和审计。UNIX 中用户身份号 UID、用户名、卡、令牌、生物特征等都可作为标识。

易考提醒：简答题要区分“标识是谁、鉴别确认是不是、授权允许做什么”。

重点 7：访问控制的两个重要过程【填空/选择易考】

参考答案：访问控制一般先鉴别，再授权。鉴别检验主体合法身份；授权限制用户对资源的访问权限。如果身份不可信，授权决策就没有可靠基础。

易考提醒：选择题问顺序时，先鉴别后授权。

重点 8：访问控制模型组成【填空/简答易考】

参考答案：访问控制模型是对一系列访问控制规则集合的描述。其组成包括主体、客体、访问控制实施功能 AEF、访问控制决策功能 ADF、主体/客体访问控制信息、策略规则和上下文信息。

易考提醒：简答题可直接写“请求提交给 AEF，AEF 请求 ADF 决策，ADF 依据属性、规则和上下文返回决策”。

重点 9：常见实现机制【填空/选择易考】

参考答案：常见实现包括访问控制表 ACL、能力表/权能表 CL、访问控制矩阵、授权关系表、访问控制安全标签、锁与钥匙等。ACL 按客体保存权限，CL 按主体保存权限，矩阵则同时描述主体与客体关系。

易考提醒：选择题要能根据“与客体关联/与主体关联”区分 ACL 和 CL。

重点 10：ACL 访问控制表【简答/应用易考】

参考答案：ACL 与客体关联，规定能够访问该客体的主体和权限。它便于查看一个客体的所有访问权限，也便于回收权限；但查看一个主体拥有的全部权限较困难。当用户和资源很多、组织变化频繁时，ACL 可能庞大且维护困难。

易考提醒：应用题若要保护文件，按文件列允许访问用户和权限，就是 ACL 思想。

重点 11：能力表 CL【简答/选择易考】

参考答案：能力表与主体关联，规定主体能访问哪些客体以及权限。它便于查看一个主体拥有的所有权限，权限传递较容易；但浏览某个客体允许哪些主体访问较困难，权限回收也较困难。

易考提醒：比较题直接按“保存位置、浏览权限、传递、回收、使用场景”答。

重点 12：访问控制矩阵【计算/应用易考】

参考答案：访问控制矩阵用主体集合 S、客体集合 O 和操作集合 A 描述权限，矩阵元素表示主体对客体的访问许可。矩阵第 i 行是主体的能力表，第 j 列是客体的访问控制表。

易考提醒：应用题给矩阵时，读行找某用户权限，读列找某文件允许谁访问。

重点 13：DAC 自主访问控制【填空/简答易考】

参考答案：DAC 允许客体属主或创建者决定主体对该客体的访问权限，灵活、易用、可扩展，常用于商业系统。但它安全性不高，是分布式授权管理模式，信息在流动中权限关系可能改变。

易考提醒：简答题写“属主决定权限、灵活但难控制信息流”。

重点 14：DAC 的特洛伊木马威胁【应用/简答易考】

参考答案：DAC 无法很好控制信息流。合法用户可把自己对目标的访问权传给其他用户，特洛伊木马也可能附在合法程序中执行非法操作而不被发现。示例中伪造 ls 命令可偷偷发送/etc/passwd。

易考提醒：应用题出现“合法程序暗中执行非法操作”，可答 DAC 难抵抗特洛伊木马。

重点 15：MAC 强制访问控制【填空/简答易考】

参考答案：MAC 中主体对客体的访问请求按强制策略控制，客体属主无权改变访问权限。主体和客体都分配安全属性，只有满足规则才允许访问。它常用于军事等高安全系统，也可与 DAC 结合。

易考提醒：简答题关键词：强制策略、安全标签、属主无权控制、安全性强。

重点 16：MAC 四种访问关系【填空/选择易考】

参考答案：MAC 涉及下读、上写、上读、下写。下读是主体级别高于客体时允许读；上写是主体级别低于客体时允许写；上读是主体级别低于客体时允许读；下写是主体级别高于客体时允许写。

易考提醒：选择题要注意“读方向”和“信息流方向”相反，写代表信息流动方向。

重点 17：BLP 模型【填空/简答/应用易考】

参考答案：Bell-LaPadula 模型用于保证机密性，核心是下读/上写，即不允许低级主体读取高级客体，也不允许高级主体把敏感信息写入低级区域。可用防火墙隔离内外网说明其机密性思想。

易考提醒：应用题保护秘密信息不外泄时，优先想到 BLP。

重点 18：Biba 模型【填空/简答/应用易考】

参考答案：Biba 模型用于保证完整性，在数学上与 BLP 对偶，核心是上读/下写，防止低完整性数据污染高完整性对象。以 Web 服务器为例：Internet 用户级别低，只能读取服务器数据，不能更改。

易考提醒：应用题保护网页不被外部用户修改时，优先想到 Biba。

重点 19：DAC 与 MAC 比较【选择/简答易考】

参考答案：DAC 细粒度、灵活性高，但配置效率低且安全性较弱；MAC 控制粒度大、灵活性不高，但安全性强。考试常让比较“灵活性”和“安全性”。

易考提醒：简答题按“授权主体、粒度、灵活性、安全性、适用场景”写。

重点 20：RBAC 基本思想【填空/简答易考】

参考答案：RBAC 根据用户所担任的角色决定用户访问权限。用户必须扮演并激活某种角色，才能访问对象或执行操作。它在用户和权限之间增加角色这一层，适合大型企业统一资源访问控制。

易考提醒：应用题设计 RBAC 时先列用户、角色、权限，再做用户-角色和角色-权限分配。

重点 21：RBAC 组成【填空/选择易考】

参考答案：RBAC 包括用户 U、角色 R、权限 P、用户分配、权限分配、激活角色和会话。权限是对客体的操作权力；用户访问系统资源时必须建立会话，一次会话对应一个用户，可激活几个角色。

易考提醒：选择题常考“角色只有激活才能起作用”。

重点 22：RBAC 关系【简答/应用易考】

参考答案：用户和角色是多对多关系，一个用户可拥有多个角色，一个角色可授予多个用户；角色和许可也是多对多关系，一个角色有多种许可，一个许可也可给多个角色。许可=操作+客体。

易考提醒：应用题可直接用银行角色例子：出纳员、分行管理者、顾客、系统管理员、审计员权限不同。

重点 23：角色继承 【选择/简答易考】

参考答案：角色继承用于避免重复设置权限。角色有自己的许可，也可继承其他角色的许可；可用医生、专家、实习医生等类似类继承关系说明。

易考提醒：选择题问 RBAC1 核心时，答案是角色继承关系。

重点 24：角色限制与互斥 【简答/应用易考】

参考答案：RBAC 可设置角色互斥和角色基数限制。角色互斥用于防止某用户同时完成某些应分离的操作，分静态互斥和动态互斥；基数限制指定某角色在特定时间内可由多少用户占用。

易考提醒：应用题如“同一人不能既审批又付款”，应写责任分离/角色互斥。

重点 25：RBAC96 模型 【填空/选择易考】

参考答案：RBAC96 包括 RBAC0、RBAC1、RBAC2、RBAC3。RBAC0 是核心；RBAC1 在 RBAC0 基础上增加角色继承；RBAC2 在 RBAC0 基础上增加约束；RBAC3 包含继承和约束，是完整模型。

易考提醒：填空题可直接背“0 核心、1 继承、2 约束、3 完整”。

高频简答/应用题参考答案

问法 1：访问控制题怎样从基本概念答起？

参考答案：先写访问控制目标：防止资源被未授权访问，使资源在授权范围内使用。再写三元组(S,A,O)：主体、操作、客体。然后说明访问控制通常先鉴别主体身份，再根据授权决定能否对客体执行读、写、执行等操作。

问法 2：ACL、CL 和访问矩阵怎么比较？

参考答案：访问矩阵全面描述主体、客体和权限关系；按列看就是 ACL，与客体关联，便于查看谁能访问某客体和回收权限；按行看就是 CL，与主体关联，便于查看某主体拥有哪些权限和传递权限。比较题抓保存位置、查看便利性、传递和回收。

问法 3：DAC 为什么灵活但安全性不高？

参考答案：DAC 由客体属主决定权限，属主可以灵活授予或撤销访问权，易用且扩展性好。但它无法有效控制信息流，用户可把权限或数据传给其他用户，特洛伊木马也可能借合法用户权限暗中操作，所以安全性不如强制访问控制。

问法 4：MAC 为什么适合高安全系统？

参考答案：MAC 给主体和客体分配安全标签，访问必须满足强制策略，客体属主无权随意改变权限。它牺牲了一定灵活性和细粒度控制，但能用统一规则阻止越权访问和非法信息流动，因此适合军事等安全要求较高的系统。

问法 5：BLP 与 Biba 应用题如何判断？

参考答案：先判断保护目标。如果题目强调防止秘密信息泄露、低级用户读取高级信息、敏感数据流向低级区域，应选 BLP，下读上写，保护机密性。如果题目强调防止低可信数据污染高完整性资源、外部用户不能修改 Web 服务器数据，应选 Biba，上读下写，保护完整性。

问法 6：RBAC 应用题如何设计？

参考答案：第一步列用户，如教师、学生、管理员；第二步列角色，如教师角色、学生角色、系统管理员角色；第三步列权限，权限=操作+客体；第四步做用户-角色分配和角色-权限分配；第五步说明通过会话激活角色，并根据需要设置角色互斥、基数限制或责任分离。

问法 7：角色继承和约束如何理解？

参考答案：角色继承用于避免重复配置，上级或子角色可继承其他角色权限。约束用于强制管理规则，例如静态角色互斥、动态角色互斥、角色基数限制。RBAC1 强调角色继承，RBAC2 强调约束，RBAC3 同时包含继承和约束。

问法 8：银行 RBAC 例子如何写？

参考答案：可按以下角色写：出纳员可修改顾客账号记录；分行管理者可修改顾客账号记录并创建、终止账号；顾客可查询自己的账号；系统管理者可开关系统但不能读写用户账号信息；审计员可读系统任何数据但不能修改。这个例子体现角色与权限分离。

本章应用题答题框架

- 访问控制方案题：先列主体、客体、操作，再选择 DAC/MAC/RBAC。
- 保密性用 BLP，完整性用 Biba；大型企业按岗位授权优先考虑 RBAC。
- 比较题直接按授权主体、灵活性、粒度、安全性、适用场景展开。

CH7 防火墙技术及其发展

本章必背关键词

防火墙；安全域；过滤；安全策略；包过滤；应用代理；状态检测；完全内容检测；过滤路由器；双宿主主机；被屏蔽主机；被屏蔽子网；DMZ；NAT；路由/透明/混合接入；性能指标；WAF。

重点知识与参考答案

重点 1：防火墙定义【填空/简答易考】

参考答案：防火墙是在网络间（内部/外部网络、不同信息级别）提供安全连接的设备，用于实现和执行网络之间通信的安全策略。也可定义为置于不同网络安全域之间的高级访问控制设备，通过策略控制允许、拒绝、监视、记录进出网络的访问行为。

易考提醒：简答题写“位置在安全域之间，核心是安全策略和访问控制”。

重点 2：防火墙的本质【判断/应用易考】

参考答案：防火墙不是简单把网络断开，而是在可信网络与不可信网络之间实施策略控制与安全隔离。它是不同安全域通信流的控制点，所有进出流量应通过它按规则检查。

易考提醒：判断题“防火墙就是完全禁止访问”错误，正确是允许合法业务、阻断非法访问。

重点 3：为什么需要防火墙【简答易考】

参考答案：主要包括三点：阻止来自不可信网络的攻击，保护关键数据完整性，维护客户对企业或机构的信任。随着业务与互联网密切相关，防火墙可减少攻击造成的泄密、篡改、删除和信誉受损风险。

易考提醒：简答题可用“城门失火，殃及池鱼”说明边界失守会影响内部系统。

重点 4：防火墙做什么【填空/简答易考】

参考答案：防火墙的核心作用是过滤。它可实现安全策略、创建阻塞点、记录 Internet 活动、限制网络暴露。通过对进出网络的数据流进行过滤与控制，使安全策略落地。

易考提醒：填空题常考“过滤、审计、访问控制”。

重点 5：防火墙发展历程【填空/选择易考】

参考答案：20 世纪 80 年代第一代包过滤；1989 年贝尔实验室推出第二代电路层防火墙；20 世纪 90 年代初出现应用层/代理防火墙；1992 年 USC 提出动态包过滤，1994 年 CheckPoint 商业化状态检测；1998 年 NAI 推出自适应代理。

易考提醒：选择题常考代际与技术对应：包过滤、电路层、应用代理、状态检测、自适应代理。

重点 6：按实现方式分类【填空/选择易考】

参考答案：防火墙从实现方式分为硬件防火墙和软件防火墙。硬件防火墙通常部署在内外网络之间，通过软硬件结合隔离内外网；软件防火墙可在独立机器上运行，通过规则限制非法访问。

易考提醒：选择题通过“部署在边界/安装在主机”区分。

重点 7：包过滤技术【简答/选择易考】

参考答案：包过滤工作在网络层，仅根据数据包头中的 IP 地址、端口号、协议类型等标志判断是否允许通过。它不检查数据区，不建立连接状态表，前后报文无关，应用层控制很弱。

易考提醒：简答题关键词：网络层、包头、IP/端口/协议、无状态、速度快但安全弱。

重点 8：包过滤优缺点【选择/简答易考】

参考答案：优点是规则简单、处理速度快、易配置、对用户透明；缺点是只在网络层检查，不能识别应用层协议或维持连接状态，安全性薄弱，不能防止 IP 欺骗等，静态策略可能成为漏洞。

易考提醒：比较题直接按“速度/透明性”和“无法识别应用/无状态/安全弱”写。

重点 9：应用代理技术【简答/选择易考】

参考答案：应用代理工作在应用层，通过不同应用代理程序对应用层数据检测和分析。它彻底隔断内外网直接通信，内网访问外网变成防火墙访问外网后再转发，应用会话必须符合代理安全策略。

易考提醒：简答题关键词：应用层、代理转发、内容检查、隔断直接 TCP 连接。

重点 10：应用代理优缺点【选择/简答易考】

参考答案：优点是可检查应用层、传输层和网络层协议特征，检测能力强，所有有效负载在应用层检查，安全性好；缺点是支持应用数量有限，难支持新应用/技术/协议，对用户不透明，性能表现欠佳。

易考提醒：应用题若要检查 FTP put 命令、URL 或敏感内容，代理更合适；若高并发大流量，代理可能成为瓶颈。

重点 11：状态检测技术【简答/选择易考】

参考答案：状态检测内置 TCP/IP 协议状态机，创建状态表维护连接上下文，检查会话连接合法性。它处理对象不是单个数据包，而是整个连接，通过规则表和连接状态表综合判断是否允许通过。

易考提醒：简答题写“状态表、连接上下文、首包严查、后续查表”。

重点 12：状态检测的 TCP/UDP 处理【应用/判断易考】

参考答案：TCP 重点检查连接阶段、返回流量和异常行为；UDP 无握手，但可根据内网主机先发起请求建立临时状态，短时间内匹配的响应允许返回，无对应请求的外部 UDP 包阻断，超时删除记录。

易考提醒：应用题出现 DNS 这类 UDP 请求，可直接写“请求-响应关系+短超时”。

重点 13：状态检测优点【选择/简答易考】

参考答案：状态检测性能大大提高，支持大量应用，可在内核级实现检测过滤，在所有接口对进/出数据包做状态检查，并支持应用层协议检查。动态状态表中存储连接状态，能预先计算出将返回的连接。

易考提醒：比较题指出它比包过滤更懂连接，比代理更轻量。

重点 14：完全内容检测【选择/简答易考】

参考答案：完全内容检测工作在 2-7 层，不仅分析包头和状态信息，还对应用层协议进行还原和内容分析，能有效防范混合型安全威胁。它同时强调网络层、应用层、会话保护和上下文相关。

易考提醒：选择题看到“2-7 层、协议还原、内容分析”选完全内容检测。

重点 15：三类防火墙对比【简答/应用易考】

参考答案：包过滤检查粒度粗、性能中等/较快、安全低到中；状态检测检查连接和状态，安全中到高、性能高；代理防火墙深入应用层内容，安全高但性能较低。三者不是互相替代，而是按流量和需求组合。

易考提醒：应用题切记“不能让一种防火墙干所有活”，要分层部署。

重点 16：过滤路由器结构【简答/判断易考】

参考答案：过滤路由器作为内外网连接唯一通道，通过 ACL 策略要求所有报文通过检查，实现报文过滤。优点结构简单、部署容易、性能高、成本低；缺点是一旦被攻陷难发现，不能识别不同用户，也没有日志记录。

易考提醒：判断题“过滤路由器可记录每个用户行为日志”应判错。

重点 17：双宿主主机结构【简答易考】

参考答案：双宿主主机位于内部网和 Internet 之间，通常用装有两块网卡的堡垒主机做防火墙。所有通信先到堡垒主机，由代理或应用服务处理后转发，系统软件可维护日志。致命弱点是一旦堡垒主机被入侵，内部网络安全无法保证。

易考提醒：答题关键词：两块网卡、堡垒主机、代理/服务、日志、主机被攻陷风险。

重点 18：被屏蔽主机结构【简答/应用易考】

参考答案：被屏蔽主机由单独路由器和内部网络上的堡垒主机共同构成，有屏蔽路由器和堡垒主机两道屏障。路由器做包过滤，堡垒主机是外部用户访问内部资源必须经过的主机，通常提供代理。弱点是堡垒主机被攻陷后内网仍受较大威胁。

易考提醒：应用题画结构时写“过滤路由器+堡垒主机”。

重点 19：被屏蔽子网/DMZ 结构【简答/应用易考】

参考答案：被屏蔽子网在内部网络与外部网络之间建立一个被隔离的子网，即 DMZ/周边网络，通常由外部路由器、内部路由器、堡垒主机和周边网络组成。外部用户一般只能访问 DMZ 资源，不能直接进入内网。

易考提醒：应用题部署公开 Web、FTP、邮件服务器时，应放在 DMZ。

重点 20：被屏蔽子网优缺点【简答易考】

参考答案：优点是外部路由器和内部路由器构成双层防护，外部用户无需进入内部网络即可访问服务；过滤规则复制可避免单台路由器失效；堡垒主机由路由器和本机机制共同保护，即使被控也难监听内网。缺点是成本较高，配置复杂，易因配置错误产生隐患。

易考提醒：简答题按“安全性提升/成本与复杂度”写。

重点 21：防火墙五个基本功能【填空/简答易考】

参考答案：五个基本功能是过滤进出网络的数据，管理进出网络的访问行为，封堵某些禁止业务，记录通过防火墙的信息内容和活动，对网络攻击进行检测和告警。

易考提醒：填空题可直接背五项。

重点 22：防火墙其他功能【选择/简答易考】

参考答案：其它功能包括控制信息流向和数据包、隐藏内部 IP 和网络结构、提供流量日志和审计、部署 NAT、连接单独网段形成 DMZ、集中执行安全规则、提供 VPN 功能。

易考提醒：选择题给“NAT、日志审计、VPN、DMZ”时都可能是防火墙功能。

重点 23：NAT 与端口映射 【应用/简答易考】

参考答案：NAT 可隐藏内部网络结构，使内部网络使用私有 IP 地址，并提供 IP 复用。MAP 地址/端口映射可让公开服务器使用私有地址，同时保证外部用户通过映射地址访问服务。

易考提醒：应用题“外部访问内部私有地址服务器”可写防火墙做端口映射/NAT。

重点 24：防火墙接入方式 【选择/简答易考】

参考答案：路由模式工作在三层，需要给内外网和 DMZ 接口配置不同网段 IP，防火墙相当于路由器；透明模式工作在二层，对用户和路由器透明，像网桥接入，不需调整已有主机配置；混合模式结合两者。

易考提醒：选择题问“不改网络拓扑/无需接口 IP”通常选透明模式。

重点 25：典型企业部署策略 【应用易考】

参考答案：企业防火墙通常把网络划分为内部网络、外部网络和 DMZ。一般策略是外部网络不允许访问内部网络，内部用户按权限访问 Internet，内外部用户只允许访问 DMZ 中指定服务器的指定服务。DMZ 服务器可用公网或私有地址，私有地址需做地址转换。

易考提醒：应用题写策略时要精确到“谁访问谁、什么服务、是否允许”。

重点 26：性能指标 【填空/计算易考】

参考答案：衡量防火墙性能的指标包括吞吐量、时延、丢包率、背靠背、并发连接数。吞吐量是不丢包情况下的最大速率；时延是入口最后 1 比特到达至出口第 1 比特输出的时间；丢包率是应转发但被丢弃帧的百分比；并发连接数是同时建立的最大连接数。

易考提醒：计算题丢包率可按“丢弃帧数/应转发帧数×100%”理解。

重点 27：防火墙局限性 【简答/判断易考】

参考答案：防火墙不能解决所有问题。它主要控制经过自身的流量，对内部攻击、绕过防火墙的链路、合法开放端口中的应用层恶意内容、配置错误、未知或复杂攻击等防护有限，因此需要 IDS、审计、主机防护、WAF、管理制度等配合。

易考提醒：判断题“部署防火墙后不需要其他安全措施”应判错。

重点 28：WAF 技术 【简答/应用易考】

参考答案：WAF 是面向 Web 应用的防护技术，适用于传统包过滤和状态检测难以识别的应用层 Web 攻击。它更关注 HTTP/HTTPS 请求、URL、参数、上传文件、敏感内容和 Web 应用行为。

易考提醒：应用题出现 SQL 注入、网页篡改、恶意上传、URL 过滤，应考虑 WAF 或应用层代理。

高频简答/应用题参考答案

问法 1：防火墙定义题怎样写得完整？

参考答案：先写位置：置于不同网络安全域之间，是通信流的控制点。再写功能：根据安全策略控制进出网络访问行为，包括允许、拒绝、监视、记录。最后写本质：在可信和不可信网络之间实施策略控制与安全隔离，而不是简单切断所有业务。

问法 2：三类核心技术如何比较？

参考答案：包过滤工作在网络层，看 IP、端口、协议，速度快、透明，但无状态、看不到应用内容；应用代理工作在应用层，能检查应用和内容，安全性高，但应用支持有限、性能较差、不透明；状态检测工作在 2-4 层，看连接上下文和状态表，性能高，安全性比包过滤好。

问法 3：为什么状态检测比包过滤更智能？

参考答案：包过滤只看单个数据包头，前后报文无关；状态检测把进出网络的数据当作会话，在核心建立状态连接表，跟踪每个会话状态。后续包不仅按规则表判断，还要看是否符合当前会话状态，因此能识别异常返回流量、伪造连接报文和动态端口协商。

问法 4：DMZ 部署题怎么写？

参考答案：先划分外部网络、DMZ、内部网络。对外 Web、邮件、FTP 等服务器放在 DMZ。策略一般是外部用户只能访问 DMZ 中指定服务器和指定端口，禁止直接访问内部网络；内部用户按权限访问外部资源；内部与 DMZ 之间也要限制，只允许必要业务。若 DMZ 用私有地址，需要 NAT 或端口映射。

问法 5：被屏蔽子网为什么安全性更高？

参考答案：它把堡垒主机放在周边网络/DMZ 中，并通过外部路由器和内部路由器实现双层隔离。外部用户访问服务时无需进入内部网络；即使堡垒主机被攻陷，内部路由器仍限制其访问内网，且外部用户无法监听内部用户之间通信。缺点是成本高、配置复杂。

问法 6：NAT 和端口映射如何说明？

参考答案：NAT 把内部私有地址转换为对外地址，隐藏内部网络结构，实现公网地址复用。端口映射把外部地址和端口映射到内部服务器地址和端口，使外部用户能访问内部私有地址服务器提供的指定服务，同时不暴露整个内部网络。

问法 7：防火墙性能指标题如何答？

参考答案：吞吐量是在不丢包情况下能达到的最大速率；时延是从入口最后 1 比特到达至出口第 1 比特输出的时间；丢包率是应转发但被丢弃的帧所占百分比；背靠背是以最小合法间隔连续发帧直到第一个帧丢失时的帧数；并发连接数是能同时建立的最大连接数。

问法 8：为什么不能让一种防火墙干所有活？

参考答案：因为不同技术取舍不同。包过滤适合快速拦截明显非法端口和地址，状态检测适合判断连接是否合法并保障性能，应用代理或 WAF 适合检查 URL、文件、命令和敏感内容。大型场景应分层组合，外层粗过滤，中间做状态检查，内层对关键应用做内容审计。

本章应用题答题框架

- 防火墙选型题：粗粒度拦截用包过滤，连接合法性用状态检测，应用内容审计或 Web 防护用代理/WAF。
- 部署题：先划分外部网络、DMZ、内部网络，再写外部访问 DMZ、禁止外部访问内网、内部按权限访问外部。
- 性能题：吞吐量、时延、丢包率、背靠背、并发连接数要能解释。

CH8 入侵检测技术及其发展

本章必背关键词

入侵；IDS；防火墙局限；预防/检测/响应；Denning 模型；IDM；SNMP-IDSM；CIDF；异常检测；特征检测；HIDS；NIDS；NNIDS；误报率；漏报率；部署位置。

重点知识与参考答案

重点 1：IDS 存在的必然性【简答/判断易考】

参考答案：网络安全威胁增长，攻击造成的破坏和损失日益严重，单纯防火墙无法防范复杂多变攻击。防火墙只能阻挡某些连接请求，但对内部攻击、合法用户滥用、APT 等复杂攻击认识有限，因此需要 IDS 作为监控和发现机制。

易考提醒：判断题“有防火墙就不需要 IDS”应判错。

重点 2：为什么需要 IDS【简答易考】

参考答案：可以从多个角度说明：单一防护产品有弱点，防御方法和策略有限，网络环境动态变化，外部和内部威胁并存。传统访问控制和加密策略在复杂系统中不充分，IDS 是安全过程的一部分。

易考提醒：简答题可直接写“安全是过程，不仅仅是人或设备，IDS 负责发现与监控”。

重点 3：入侵定义【填空/简答易考】

参考答案：入侵是在非法或未经授权情况下，试图存取或处理系统或网络中的信息，或破坏系统/网络正常运行，使机密性、完整性、可用性受到破坏的故意行为。

易考提醒：填空题重点：非法/未经授权、存取/处理信息、破坏运行、CIA 受损、故意行为。

重点 4：入侵分类【选择易考】

参考答案：攻击类型包括网络嗅探、利用设计缺陷、实现缺陷、拒绝服务等；攻击对象可针对网络、操作系统、应用。

易考提醒：选择题给“DoS”属于拒绝服务，给“漏洞利用”属于利用实现或设计缺陷。

重点 5：针对入侵的防御系统【简答易考】

参考答案：深度防御中防止入侵要从预防入侵、检测入侵、对入侵做出响应三方面着手。预防解决能不能挡住，检测解决攻击发生后能不能发现，响应解决发现后如何减小损害并恢复服务。

易考提醒：简答题按“预防-检测-响应”三段写。

重点 6：入侵检测与 IDS【填空/简答易考】

参考答案：入侵检测是对入侵行为的发觉，通过网络或系统关键点采集信息并分析，发现违反安全策略的行为和被攻击迹象。IDS 是实现入侵检测功能的软件和硬件集合。

易考提醒：判断题“IDS 只是一个硬件盒子”错误，可能是软件、硬件或集合。

重点 7：IDS 的作用【简答易考】

参考答案：IDS 可作为防火墙补充，检测来自内部网络的攻击，克服传统防御机制限制，在深度防御基础上成为安全框架一部分，并在组织网络中识别入侵或违反安全策略行为并做出回应。

易考提醒：简答题卷面要写“补充防火墙、内部攻击、识别违规、回应”。

重点 8：IDS 的功能【填空/简答易考】

参考答案：IDS 功能包括自动检测入侵行为，监视网络流量和主机操作，分析入侵行为（基于特征或基于异常），按预定规则做出响应并阻止指定行为。

易考提醒：填空题常考“监视、分析、响应”。

重点 9：Denning 通用模型【选择/简答易考】

参考答案：Denning 模型假设异常使用系统的入侵行为可通过检查系统审计记录来识别。它是基于规则的模式匹配系统，能检测黑客入侵、未授权或越权操作等，但未包含已知系统漏洞或攻击方法方面的知识。

易考提醒：简答题关键词：审计记录、异常使用、规则匹配、通用框架。

重点 10：Denning 审计记录格式【填空/选择易考】

参考答案：审计记录格式为<Subject, Action, Object, Exception-Condition, Resource-Usage, Time-Stamp>，分别表示主体、操作、客体、异常条件、资源使用、时间戳。事件包括用户注册、命令执行、文件访问等。

易考提醒：填空题要能写六个字段中文含义。

重点 11：Denning 活动剖面【简答易考】

参考答案：活动剖面保存主体正常活动信息，随机变量包括事件计数器、间隔计时器、资源计量器，可从事件数量、频度、资源消耗等方面度量行为是否异常。

易考提醒：简答题写“正常轮廓/简档+统计变量+阈值比较”。

重点 12：IDM 层次化模型【填空/简答易考】

参考答案：IDM 把分散原始数据抽象为高层入侵和安全假设，分六层：数据层、事件层、主体层、上下文层、威胁层、安全状态层。它通过数据加工、抽象和关联简化跨越单机的入侵识别。

易考提醒：填空题按由低到高背六层。

重点 13：SNMP-IDSM 管理式模型【简答易考】

参考答案：SNMP-IDSM 从网络管理角度解决不同 IDS 之间信息交换困难的问题，以 SNMP 为公共语言实现 IDS 之间消息交换和协同检测，定义 IDS-MIB 描述入侵事件。攻击事件描述可包括 where、when、who、what、how。

易考提醒：简答题关键词：SNMP、IDS-MIB、协同检测、事件交换。

重点 14：CIDF 通用架构【填空/简答易考】

参考答案：CIDF 把 IDS 需要分析的数据统称为事件，可以是网络数据包，也可以是系统日志等信息。逻辑组件包括事件生成器、事件分析器、事件响应器、事件数据库。

易考提醒：填空题常考四个组件。

重点 15：CIDF 四组件作用【简答易考】

参考答案：事件生成器采集和监视被保护系统数据并保存；事件分析器分析数据、发现异常并通知响应；事件数据库记录事件和分析结果；事件响应器根据分析结果拦截、阻断、反追踪等，保护系统免受攻击和破坏。

易考提醒：简答题按“四组件+作用”写。

重点 16：IDS 组成流程【简答易考】

参考答案：入侵检测系统通常包括信息采集、信息分析、攻击响应。采集来源包括系统日志、目录和文件完整性、程序执行异常、物理形式入侵信息等；分析可用统计、常规活动、神经网络、专家系统、完整性分析；响应包括报警、终止连接、断开链路、引入陷阱等。

易考提醒：答题可按“采集什么-怎样分析-如何响应”三段写。

重点 17：IDS 分类【填空/选择易考】

参考答案：按检测分析技术分为异常检测和特征检测；按检测范围分为基于主机 HIDS、基于网络 NIDS、基于网络节点 NNIDS。

易考提醒：选择题常考两个分类维度。

重点 18：异常检测【简答/选择易考】

参考答案：异常检测也称基于行为的检测，先建立用户或系统正常使用模式，再标识不符合正常模式的活动。它假设入侵行为是异常的，可检测未知攻击，具有自适应/自学习潜力，但正常模式难建立，误报和漏报可能较高，合法行为突然变化也会误警。

易考提醒：比较题写“能发现未知攻击但误报高”。

重点 19：异常检测技术【选择/简答易考】

参考答案：异常检测常用技术包括目标完整性检测、量化分析、门限检测、基于传统统计方法、隐马尔科夫模型、神经网络、免疫学、遗传算法、支持向量机等。Tripwire 是文件系统完整性检查工具。

易考提醒：选择题问“Tripwire 属于什么”，可答目标完整性/文件完整性检查。

重点 20：特征检测【简答/选择易考】

参考答案：特征检测也称误用检测，针对已知或类似攻击行为以及违背安全策略行为，建立入侵行为模型或攻击特征库，判断当前活动是否符合已知攻击模式。优点是准确率高、算法简单；缺点是特征库需要不断更新，无法检测新的入侵。

易考提醒：比较题写“已知攻击准确，未知攻击无力”。

重点 21：特征检测方法【选择易考】

参考答案：特征检测方法包括基于攻击签名分析、简单规则模式匹配、专家系统、统计模式匹配、状态转换分析、模型推理、神经网络等。状态转换分析可考虑每步攻击对系统状态的影响，检测协同攻击和利用用户会话的攻击。

易考提醒：选择题看到“攻击签名/规则库”多为特征检测。

重点 22：HIDS 主机入侵检测【简答易考】

参考答案：HIDS 以代理软件形式安装在每台主机或服务器上，监测主机活动，并向统一管理/策略服务器发送日志和告警。检测对象包括网络连接检测和主机文件检测，后者关注系统日志、文件系统、进程记录等。

易考提醒：简答题写“装在主机、看主机日志/文件/进程、可映射用户”。

重点 23：HIDS 优缺点【选择/简答易考】

参考答案：HIDS 优点是长期监控谁访问什么，可映射具体用户 ID，可跟踪滥用行为变化，适用于加密和交换环境；缺点是无法监测网络活动，增加系统负载，审计记录占空间，代理可能被操作系统漏洞破坏，不同系统需不同代理，部署维护成本较高。

易考提醒：比较题写“看主机强，看网络弱；适合加密，但成本高”。

重点 24：NIDS 网络入侵检测【简答易考】

参考答案：NIDS 作为独立个体放在被保护网络上，以混杂模式接入，传感器部署在关键位置，使用原始网络分组作为分析数据源，实时监视和分析网络通信，发现攻击后通过通知、报警、中断连接等方式响应。

易考提醒：部署题要写“旁路接入、关键位置、端口镜像”。

重点 25：NIDS 优缺点【选择/简答易考】

参考答案：NIDS 优点是不需重配日志即可快速获取信息，不影响现有网络架构或数据源，实时监测网络攻击或误用，与操作系统无关，不增加主机开销。缺点是无法分析加密数据，只能从流量推断发生了什么但不能判断结果，全交换网络需要端口镜像，对带宽要求高。

易考提醒：比较题写“部署轻、看网络；看不到加密与主机结果”。

重点 26：网络节点入侵检测【填空/简答易考】

参考答案：网络节点入侵检测系统安装在网络节点主机中，结合 NIDS 和 HIDS 技术，适合高速交换环境和加密环境。

易考提醒：选择题问“结合 NIDS 与 HIDS、适合交换和加密”，选网络节点 IDS。

重点 27：入侵响应方式【填空/简答易考】

参考答案：响应方式包括 IDS 控制台显示告警，通过电子邮件向管理员发送告警，根据预设规则阻断连接，IDS 自身阻断，与防火墙联动；还要采取事件归并，防止响应机制被攻击者利用造成拒绝服务。

易考提醒：简答题写“报警、通知、阻断、联动、事件归并”。

重点 28：误报率和漏报率【填空/判断易考】

参考答案：误报率 false alarm rate 是把正常事件识别为攻击并报警；漏报率 false negative 是攻击事件没有被 IDS 检测到。误报率与检出率成正比例关系，实际部署需要在检出率和误报之间权衡。

易考提醒：判断题“漏报就是把正常当攻击”错误，那是误报。

重点 29：IDS 典型部署位置【应用/简答易考】

参考答案：检测器放在路由器和边界防火墙之间，可审计来自 Internet 对保护网络的攻击数量和类型；放在 DMZ 可查看受保护区域主机被攻击状态和防火墙策略合理性；放在主要网络中枢可监控大量数据；放在高安全级子网可保护重要系统资源。

易考提醒：部署题要根据“想看什么流量”选择位置并写理由。

高频简答/应用题参考答案

问法 1：IDS 作用题怎样答？

参考答案：先写 IDS 是实现入侵检测的软件和硬件集合，通过在网络或系统关键点采集并分析信息，发现违反安全策略或被攻击迹象。再写作用：作为防火墙补充，检测内部攻击，克服传统防御限制，识别入侵或违规行为并响应。

问法 2：预防、检测、响应如何区分？

参考答案：预防入侵是采取措施阻止不良企图，但攻击仍可能因漏洞、隧道技术、内部攻击而发生；检测入侵是实时分析网络流量、主机行为和审计数据，识别入侵或误用；响应入侵是在识别后报警、阻断、减小损害并恢复服务。

问法 3：Denning 模型如何答？

参考答案：Denning 模型假设异常使用系统的入侵可通过检查审计记录识别。审计记录包含主体、操作、客体、异常条件、资源使用、时间戳。模型使用活动剖面描述正常行为，通过事件计数器、间隔计时器、资源计量器等变量发现异常，是一种基于规则的模式匹配框架。

问法 4：CIDF 通用模型如何答？

参考答案：CIDF 把网络包、系统日志等都称为事件。组件包括事件生成器、事件分析器、事件数据库、事件响应器。生成器负责采集和保存事件，分析器识别非法或异常现象，数据库保存事件与分析结果，响应器在发现入侵企图后执行报警、阻断或反追踪等动作。

问法 5：异常检测和特征检测如何比较？

参考答案：异常检测先建立正常行为模型，再找偏离正常的活动，优点是可检测未知攻击，有自适应潜力，缺点是正常模型难建、误报高。特征检测建立攻击特征库，匹配已知攻击模式，优点是准确率高、算法简单，缺点是特征库需更新，不能发现全新攻击。

问法 6：HIDS 和 NIDS 如何比较？

参考答案：HIDS 安装在主机或服务器上，看系统日志、文件系统、进程和主机连接，可映射到用户 ID，适合加密和交换环境，但增加主机负载、维护成本高、看不到全网流量。NIDS 部署在网络关键位置，看网络包和流量，部署不影响主机，实时监控网络攻击，但无法分析加密数据，难判断攻击结果，交换环境需端口镜像。

问法 7：误报率和漏报率如何解释？

参考答案：误报率是把正常事件识别为攻击并报警，会增加管理员负担；漏报率是攻击事件没有被 IDS 发现，会导致真实攻击被放过。实际系统中检出率提高可能带来误报率上升，因此要根据业务重要性、告警处理能力和安全目标进行权衡。

问法 8：IDS 部署位置题怎么答？

参考答案：边界路由器和防火墙之间能看到来自 Internet 的攻击数量和类型；DMZ 区域能观察公开服务被攻击情况和防火墙策略是否合理；主要网络中枢能监控大量流量，提高发现攻击概率；高安全级子网适合保护重要系统和资源。答题要说明“放这里能看见什么”。

本章应用题答题框架

- 检测技术题：异常检测强调正常模型和未知攻击，特征检测强调特征库和已知攻击。
- 部署题：根据想监控的流量选择边界、DMZ、核心中枢或高安全子网。
- HIDS/NIDS 比较题：按数据源、可见性、加密环境、部署成本和局限作答。

CH1 网络空间安全概述

1. 为什么会有信息安全问题？【简答/应用题易考】

参考答案：不能只写“因为有黑客、病毒、漏洞”。根源包括内因和外因：内因是信息系统越来越复杂，工作计算机、员工、移动介质、内网其他系统、互联网连接、无线网络、远程用户、厂商访问等都会扩大攻击面；外因包括国家安全威胁、恐怖分子、商业间谍、犯罪团伙、黑客以及自然破坏。最后要补充“人是最薄弱环节”，技术、管理和人员意识都会影响安全。

2. 什么是信息安全的 CIA 目标？【简答/应用题易考】

参考答案：CIA 是信息安全最基础的三个目标。机密性是防止信息被非授权泄露和非授权使用，即“不该知道的人不让知道”；完整性是防止信息被非法篡改、插入、删除和破坏，保证信息正确、完整；可用性是保证授权用户或程序能够及时、正常、可靠地使用信息。应把三个英文缩写和中文含义都写清楚。

3. 信息安全为什么不能只靠技术？【简答/应用题易考】

参考答案：技术很重要，但技术不是一切。信息依赖信息技术系统，所以需要技术控制；信息系统由人建设、使用和维护，所以需要管理约束；今天安全明天未必安全，所以需要贯穿生命周期的工程过程；信息安全对抗归根结底是人员知识、技能和素质的对抗，所以要建设高素质人才队伍。

4. 如何用木桶原理解释安全短板？【简答/应用题易考】

参考答案：木桶容量取决于最短木板，信息安全整体水平也取决于最薄弱环节。单位即使部署了防火墙、入侵检测和认证系统，如果员工随便插 U 盘、服务器不锁屏、默认口令不改、补丁不打，核心数据仍可能泄露。答题要强调“技术、制度、人员、运维、意识必须同时建设”。

5. 网络空间安全趋势如何概括？【简答/应用题易考】

参考答案：可概括为隐蔽性和趋利性。隐蔽性是指安全问题看不见摸不着，用户可能在不知不觉中感染病毒或遭受损失；趋利性是指为了炫耀能力的黑客减少，为了政治、经济利益进行攻击的人增多。新应用如 AI、大数据、云计算、物联网、5G 和 Web2.0 也带来新的安全问题。

6. 为什么网络安全上升到国家安全高度？【简答/应用题易考】

参考答案：网络安全和信息化事关国家安全、国家发展以及人民工作生活。网络空间涉及政治、经济、文化、社会治理、国防和国际合作等多个方面，因此不能把网络安全仅理解为某台电脑或某个单位的技术问题。答题可引用“没有网络安全就没有国家安全，没有信息化就没有现代化”的经典表述。

易错判断/选择题陷阱

易错说法/干扰项	判断与理由
有了最好的技术设备就绝对安全	错误。人和管理仍可能成为突破口。
信息安全问题只来源于黑客和病毒	错误。系统复杂性、威胁、自然破坏和人员意识都可能导致问题。
CIA 中的 A 表示真实性	错误。A 是 Availability，可用性。
完整性只是不缺页	错误。重点是防止篡改和破坏。

CH2 信息安全风险管理与国产化替代

1. 什么是网络空间安全风险管理？【简答/应用题易考】

参考答案：风险管理是在肯定存在风险的环境中，把风险降低到可接受水平的管理过程。网络空间安全风险管理可概括为“了解风险+控制风险=管理风险”。它不是追求零风险，也不是平均处理所有风险，而是识别、优化、管理风险，把最可能发生且损失最大的风险优先处理，从而用有限资源实现较好的安全效果。

2. 如何说明风险五要素及其关系？【简答/应用题易考】

参考答案：风险可从威胁源、威胁行为、脆弱性、资产、影响五方面理解。威胁源采取威胁方式，利用资产或系统中的脆弱性，造成不良后果并影响组织资产。控制措施用于减少威胁、降低脆弱性、防护资产或降低影响。应用题要按“谁、用什么方法、利用什么弱点、作用于什么资产、造成什么影响”展开。

3. 风险管理工作内容有哪些？【简答/应用题易考】

参考答案：风险管理工作可概括为四个阶段、两个贯穿：建立背景、风险评估、风险处理、批准监督，以及贯穿全过程的监控审查、沟通咨询。建立背景确定对象、范围、团队和计划；风险评估识别威胁、脆弱性和控制措施并判定等级；风险处理选择处置措施；批准监督由决策层认可并监督变化；监控审查和沟通咨询保证过程持续有效。

4. 四类风险处置方法如何区分？【简答/应用题易考】

参考答案：减低风险是采取保护措施降低风险，通常优先考虑；转移风险是把风险或资产价值转移给第三方，如保险或外包；规避风险是不使用面临风险的资产，如敏感信息不放入安全保障不足的系统；接受风险是在成本效益或现实条件下不再进一步处理，但接受不等于不管，仍要持续监控风险态势。

5. ALE 和 ROSI 计算题怎样写？【简答/应用题易考】

参考答案：先写变量含义：AV 是资产价值，EF 是暴露系数，SLE 是单一预期损失，ARO 是年发生率，ALE 是年预期损失。公式为 SLE=AV×EF，ALE=SLE×ARO=AV×EF×ARO。ROSI=实施控制前 ALE−实施控制后 ALE−年控制成本。最后要根据结果说明控制措施是否具有成本效益。

6. 为什么要进行国产化替代？【简答/应用题易考】

参考答案：核心技术、自主可控和安全可控。芯片、基础软件、中间件等关键领域若长期被国外企业垄断，关键领域命脉掌握在别人手中始终不安全。国产化替代不是简单换品牌，而是围绕 CPU、操作系统、数据库、中间件、云计算、软件、硬件、安全等形成自主可控的信息技术体系和信创生态。

易错判断/选择题陷阱

易错说法/干扰项	判断与理由
风险评估就是风险管理	错误。风险评估只是风险管理的阶段之一。
接受风险就是不用再管风险	错误。接受风险仍需监控。
残余风险一定是不重要的风险	错误。残余风险是采取措施后仍存在或暂不控制的风险。
定量分析适合所有场景	错误。定性、定量各有优缺点。

CH3 信息与网络空间安全保障

1. 信息有哪些性质？【简答/应用题易考】

参考答案：信息具有依附性、可伪性、动态性、可处理性、共享性、可传递性、异步性和可交换性。答题可用微信通信解释：消息必须依附文字、语音或图片；内容可能被伪造；通知会随情况变化；可复制、截图、搜索和转发；群消息可共享；发送者和接收者不必同时在线；一问一答完成信息交换。

2. 网络空间安全的特征和范畴是什么？【简答/应用题易考】

参考答案：网络空间安全是系统的安全、动态的安全、无边界的安全和非传统的安全。它的范畴不仅包括信息技术问题，也包括组织管理问题、社会问题和国家安全问题。答题时要强调网络安全不只是设备和软件安全，还涉及人、技术系统、组织环境、法制、舆论、信息战和虚拟空间。

3. PDR、PDRR、PPDR 如何理解？【简答/应用题易考】

参考答案：PDR 包括保护、检测、响应，强调承认漏洞、正视威胁、适度防护、加强检测和落实反应。PDRR 在 PDR 基础上增加恢复，强调系统被入侵后恢复到正常状态。PPDR 把策略作为核心，在统一安全策略指导下进行防护、检测和响应，形成完整、动态的安全循环，更强调安全的动态性和管理因素。

4. PPDR 时间公式如何作答？【简答/应用题易考】

参考答案：Pt 表示防护时间，Dt 表示从攻击发起到检测到攻击的时间，Rt 表示从检测到攻击到处理完成的时间。若 Pt>Dt+Rt，说明防护能够撑到检测和响应完成，系统是安全的；若 Pt<Dt+Rt，则暴露时间 Et=(Dt+Rt)−Pt。计算题要先写变量含义，再比较大小并给出结论。

5. IATF 深度防御包括什么？【简答/应用题易考】

参考答案：IATF 的代表思想是深度防御，强调人、技术、操作三个核心要素，并关注本地计算环境、区域边界、网络和基础设施、支撑性基础设施四个技术焦点领域。它不是依赖单一防线，而是在主机、边界、网络、密钥管理、检测响应等方面多层防护，以保障组织任务和业务运作。

6. 信息系统安全保障模型怎样展开？【简答/应用题易考】

参考答案：信息系统安全保障是在系统整个生命周期中，从技术、管理、工程和人员等方面提出安全保障要求，确保机密性、完整性和可用性，把风险降低到可接受程度，最终保障组织业务使命。答题要写出生命周期、保障要素、安全特征三类维度，并强调业务使命是根本目的。

易错判断/选择题陷阱

易错说法/干扰项	判断与理由
PPDR 的第一个 P 是 Protection	错误。PPDR 的第一个 P 是 Policy 策略。
Pt<Dt+Rt 表示安全	错误。Pt>Dt+Rt 才表示安全。
IATF 只强调技术	错误。IATF 强调人、技术、操作三要素。
安全保障最终目的只是保护设备	错误。最终目的是保障业务使命。

CH4 网络空间安全技术体系与机制

1. OSI 安全体系结构的五种安全服务是什么？【简答/应用题易考】

参考答案：五种安全服务是鉴别、访问控制、数据机密性、数据完整性和抗抵赖。鉴别确认对等实体或数据来源；访问控制防止非授权使用资源；机密性防止非授权泄露；完整性防止篡改、插入、删除并可检测；抗抵赖提供发送或接收行为的证据，使相关方不能否认。

2. 八种基本安全机制如何记忆？【简答/应用题易考】

参考答案：八种基本安全机制包括加密、数字签名、访问控制、数据完整性、鉴别交换、通信业务流填充、路由选择控制和公证机制。答题时要说明机制用途：加密保护机密性；数字签名支持不可伪造和不可抵赖；访问控制限制资源使用；完整性机制检测篡改；鉴别交换确认身份；业务流填充对抗流量分析；路由控制选择安全路径；公证由第三方证明通信事实。

3. 安全服务和安全机制如何避免混淆？【简答/应用题易考】

参考答案：安全服务回答“要提供什么安全能力”，安全机制回答“用什么技术实现”。例如数据机密性是安全服务，加密是常用实现机制；抗抵赖是安全服务，数字签名和公证机制可以支持抗抵赖。考试选择题常把二者混在一起，答题时应先判断题干问的是目标能力还是实现技术。

4. 信息系统安全体系框架由什么构成？【简答/应用题易考】

参考答案：完整的信息系统安全体系框架由技术体系、组织机构体系和管理体系共同构建。技术体系包括物理安全、系统安全等；组织机构体系由机构、岗位、人事构成，机构包括决策层、管理层和执行层；管理体系由法律管理、制度管理和培训管理组成。“三分技术，七分管理；管理与技术并重”。

5. 网络空间安全技术按层次如何分类？【简答/应用题易考】

参考答案：安全防范技术体系可分为物理层安全、系统层安全、网络层安全、应用层安全和管理层安全。物理层关注线路、机房、设备和环境；系统层关注操作系统漏洞、配置和病毒；网络层关注网络身份鉴别、访问控制、传输机密完整、远程接入、DNS 和路由安全、入侵检测；应用层关注 Web、邮件、DNS 等应用和数据；管理层关注制度、组织职责和人员角色。

6. MAC、消息摘要、数字签名的区别是什么？【简答/应用题易考】

参考答案：MAC 利用共享密钥生成消息认证码，可让接收者确信消息未被修改，但不提供保密作用；消息摘要用哈希函数产生固定长度摘要，效率高但若攻击者同时修改消息和摘要，就需要与加密或签名结合；数字签名用私钥和非对称密码算法产生，可验证完整性、来源并支持抗抵赖，但用非对称密码加密整个消息速度较慢。

易错判断/选择题陷阱

易错说法/干扰项	判断与理由
安全服务就是安全机制	错误。服务是目标能力，机制是实现手段。
MAC 具有保密作用	错误。MAC 主要用于完整性/认证，不提供保密。
业务流填充用于提高带宽	错误。主要用于对抗流量分析。
管理不是安全体系组成部分	错误。管理是安全体系的重要部分。

CH5 鉴别机制与技术

1. 什么是鉴别，为什么重要？【简答/应用题易考】

参考答案：鉴别就是确认实体是它所声明的，提供关于实体身份的保证，是最重要的安全服务之一。访问控制依赖鉴别来确定主体身份，审计依赖鉴别把行为和责任关联起来，数据完整性也可结合数据源鉴别使用。鉴别主要用于对抗假冒威胁，因此网络安全中的授权、审计和责任追踪都以鉴别为前提。

2. 实体鉴别系统由哪些角色组成？【简答/应用题易考】

参考答案：实体鉴别系统包括示证者/声称者 P、验证者 V、可信第三方 TP 和攻击者。P 提交身份并声称自己是某主体；V 检验证件或鉴别信息的正确性和合法性；TP 可参与调解、分发证书或提供验证支持；攻击者可能窃听、重放、伪造或冒充声称者来骗取验证者信任。

3. 网络环境下身份鉴别有哪些需求？【简答/应用题易考】

参考答案：网络环境下需要唯一身份标识，如 uid、uid@domain 或 DN；要抵抗被动威胁，口令不能在网上明文传输；要抵抗主动威胁，如阻断、伪造、重放等，网络上传输的鉴别信息应不可重用。简答题可概括为“唯一标识、防窃听、防伪造、防重放、必要时依赖可信第三方”。

4. 实现鉴别的三类途径是什么？【简答/应用题易考】

参考答案：身份鉴别可基于你所知道的内容，如口令、密码；基于你所拥有的物品，如身份证、信用卡、智能卡、令牌；基于你的个人特征，如指纹、笔迹、声音、手型、脸型、视网膜、虹膜。实际系统常采用双因素或多因素认证，并在安全水平、系统通过率、用户可接受性和成本之间权衡。

5. 口令机制有哪些弱点和对策？【简答/应用题易考】

参考答案：口令机制常见弱点包括外部泄露、口令猜测、线路窃听、危及验证者和重放攻击。对策包括教育培训、严格管理、定期更改口令、限制非法登录次数、插入实时延迟、限制最小长度、防止用户特征相关口令、及时更改默认口令、使用单向函数、加盐、一次性口令和质询-应答。

6. 零知识证明的核心原则是什么？【简答/应用题易考】

参考答案：零知识证明要求证明者在不泄露秘密本身的情况下，让验证者相信其确实知道秘密或具备某种能力。核心原则包括完备性，即真实证明者能够通过验证；合理性，即不知道秘密者难以冒充；零知识，即验证者只获得“证明者具备能力”这一信息，不获得秘密内容。洞穴问题是典型说明。

易错判断/选择题陷阱

易错说法/干扰项	判断与理由
鉴别和认证完全相同	不严谨。要区分 Authentication 和 Certification。
1 级鉴别可以防重放	错误。1 级主要抗泄露，仍易受重放攻击。
加盐能解决所有口令攻击	错误。主要增加字典/彩虹表攻击难度。
零知识证明要把秘密告诉验证者	错误。零知识证明不泄露秘密本身。

CH6 访问控制机制与技术

1. 什么是访问控制？【简答/应用题易考】

参考答案：访问控制是针对越权使用资源的防御措施，目标是防止对计算资源、通信资源或信息资源进行未授权访问，使资源在授权范围内使用。它决定用户能做什么，也决定代表用户利益的程序能做什么。未授权访问包括未经授权的使用、泄露、修改、销毁信息以及颁发指令等。

2. 主体、客体和访问三元组如何理解？【简答/应用题易考】

参考答案：主体是访问发起者，是主动实体，如用户、程序、进程；客体是被操作的被动实体，是需要保护的资源，如文件、存储介质、程序、进程；访问是主体对客体执行的操作，如读、写、修改、删除、执行。访问可描述为三元组(S,A,O)，即主体、访问操作、客体。

3. ACL、能力表和访问控制矩阵如何比较？【简答/应用题易考】

参考答案：访问控制矩阵的行表示主体，列表示客体，元素表示主体对客体的权限。按列保存就是访问控制表 ACL，与客体关联，容易查看某客体允许谁访问，也容易回收权限；按行保存就是能力表 CL，与主体关联，容易查看某主体有哪些权限，但回收某客体权限困难。表格题要写清保存位置和优缺点。

4. DAC、MAC 和 RBAC 有什么区别？【简答/应用题易考】

参考答案：DAC 由客体属主决定访问权限，灵活、易用、常用于商业系统，但安全性不高，权限可能被传播；MAC 由系统强制策略控制，主体和客体有安全级别或标签，属主无权随意改变，安全性强但灵活性低；RBAC 根据用户担任的角色授予权限，适合大型组织按岗位进行授权管理。

5. BLP 和 Biba 模型分别解决什么问题？【简答/应用题易考】

参考答案：BLP 模型用于保护机密性，规则可概括为下读/上写，即高级别主体可以读低级别客体，低级别主体不能读高级别信息，高级信息不能向低级泄露。Biba 模型用于保护完整性，规则可概括为上读/下写，防止低完整性信息污染高完整性对象。应用题中“防泄密”优先想到 BLP，“防污染/防篡改”优先想到 Biba。

6. RBAC 应用题如何答完整？【简答/应用题易考】

参考答案：RBAC 应用题应按用户、角色、权限、会话四步写。先识别组织岗位并定义角色，再把操作和客体组合成权限，然后把权限分配给角色，把用户分配给角色。用户登录后建立会话并激活授权角色才能访问资源。对于重要业务，应补充角色互斥、角色基数限制、静态/动态责任分离，避免一个用户完成冲突操作。

易错判断/选择题陷阱

易错说法/干扰项	判断与理由
身份鉴别不是访问控制前提	错误。访问控制要先确认主体身份。
DAC 一定比 MAC 安全	错误。DAC 灵活，MAC 安全性通常更强。
BLP 保护完整性，Biba 保护机密性	错误。BLP 偏机密性，Biba 偏完整性。
RBAC 中用户绕过角色直接获得权限	错误。RBAC 通过角色间接授权。

CH7 防火墙技术及其发展

1. 什么是防火墙？【简答/应用题易考】

参考答案：防火墙是一种高级访问控制设备，置于不同网络安全域之间，通过相关安全策略控制进出网络的访问行为，包括允许、拒绝、监视和记录。它通常是两个安全域之间通信流的唯一通道，本质是在可信网络与不可信网络之间实施策略控制与安全隔离。

2. 为什么需要防火墙？【简答/应用题易考】

参考答案：防火墙的价值在于让外部访问可控，让内部系统更安全。可从三个原因：阻止来自不可信网络的攻击，保护关键数据的完整性，维护客户对企业或机构的信任。它不是简单把网络断开，而是在允许业务访问和阻断非法访问之间建立安全边界。

3. 包过滤、应用代理、状态检测如何比较？【简答/应用题易考】

参考答案：包过滤工作在网络层，只看 IP 地址、端口、协议等头部信息，速度快、配置简单、对用户透明，但不理解应用层和连接状态。应用代理工作在应用层，可检查应用内容，安全性较好，但对用户不透明、性能较差、支持应用有限。状态检测工作在 2-4 层，建立连接状态表，判断数据包是否属于合法会话，兼顾性能和安全。

4. 防火墙体系结构有哪些？【简答/应用题易考】

参考答案：常见结构包括过滤路由器、多宿主主机、被屏蔽主机、被屏蔽子网。过滤路由器通过 ACL 过滤报文；双宿主/多宿主主机用堡垒主机连接内外网并提供代理和日志；被屏蔽主机由屏蔽路由器和堡垒主机构成两道屏障；被屏蔽子网在内外网之间建立 DMZ，由外部路由器、内部路由器、周边网络和堡垒主机构成。

5. 为什么 DMZ 比只有边界防火墙更安全？【简答/应用题易考】

参考答案：DMZ 把对外服务主机放在内部网络和外部网络之间的周边网络。外部用户通常只能访问 DMZ 资源而不能直接访问内网，内部核心数据库和业务系统不直接暴露。即使 DMZ 堡垒主机被攻陷，内部路由器仍可限制其访问内网，外部用户也难以监听内部网络通信。因此 DMZ 适合部署 Web、FTP、邮件、DNS 等对外服务。

6. 防火墙有哪些局限性？【简答/应用题易考】

参考答案：防火墙不能防范不经过它的攻击，不能完全防范内部攻击，不能防止策略允许流量中携带的所有恶意内容，也不能代替主机安全、补丁、鉴别、审计、入侵检测和人员管理。若配置错误或安全策略不合理，防火墙自身也可能成为安全隐患。因此防火墙有价值但不是完整安全体系。

易错判断/选择题陷阱

易错说法/干扰项	判断与理由
包过滤能检查应用层内容	错误。包过滤主要检查报头。
状态检测只看单个数据包	错误。它关注连接状态和上下文。
DMZ 就是内部核心数据库区	错误。DMZ 是对外服务/周边网络。
防火墙可以防所有攻击	错误。防火墙有局限，需要配合其他措施。

CH8 入侵检测技术及其发展

1. 为什么需要 IDS？【简答/应用题易考】

参考答案：单纯防火墙无法防范复杂多变攻击，也无法处理很多内部攻击、APT 攻击或合法用户滥用。IDS 用于实时监控网络安全状态，作为防火墙补充，在深度防御中发现入侵或违反安全策略的行为，并通过报警、阻断、联动等方式响应。安全是过程，不仅仅是设备，IDS 是安全体系的一部分。

2. 什么是入侵检测和 IDS？【简答/应用题易考】

参考答案：入侵检测是对入侵行为的发觉，通过在计算机网络或系统关键点采集信息并分析，从中发现违反安全策略的行为或被攻击迹象。IDS 是实现入侵检测功能的软件和硬件集合。其目标是发现非授权使用、合法用户滥用以及软件错误、认证模块失效、不当系统管理带来的安全缺陷。

3. Denning 模型如何理解？【简答/应用题易考】

参考答案：Denning 模型是通用入侵检测框架，假设入侵行为可通过检查系统审计记录识别。审计记录格式包括 Subject、Action、Object、Exception-Condition、Resource-Usage、Time-Stamp。模型通过活动剖面保存正常行为信息，再用规则集处理引擎分析审计记录，发现异常时产生异常记录并采取动作。

4. 异常检测和特征检测如何比较？【简答/应用题易考】

参考答案：异常检测先建立用户或系统正常行为模型，再把偏离正常模式的行为标记为可疑，优点是可发现未知攻击、自适应、自学习，缺点是正常模式难建立、误报漏报较高。特征检测根据已知攻击方法和特征库判断是否发生入侵，优点是准确率高、算法简单，缺点是依赖特征库更新，难发现新的未知攻击。

5. HIDS、NIDS、NNIDS 如何区分？【简答/应用题易考】

参考答案：HIDS 安装在主机上，以代理软件监测系统日志、文件系统、进程记录等，能映射到用户 ID，适合加密环境，但负载和维护成本高。NIDS 独立部署在网络关键位置，以混杂模式分析网络数据包，不影响主机，但不能分析加密数据。NNIDS 安装在网络节点主机中，结合 HIDS 和 NIDS，适合高速交换和加密环境。

6. IDS 如何部署才更有价值？【简答/应用题易考】

参考答案：IDS 通常旁路接入网络关键位置。放在路由器和边界防火墙之间可审计来自 Internet 的攻击数量和类型；放在 DMZ 可查看受保护区域主机被攻击状态和防火墙策略是否合理；放在网络中枢可监控大量数据并发现越权行为；放在高安全级别子网可保护重要系统和资源。

易错判断/选择题陷阱

易错说法/干扰项	判断与理由
IDS 可以完全替代防火墙	错误。IDS 是补充不是替代。
异常检测依赖已知特征库	错误。这是特征检测特点。
特征检测能发现所有未知攻击	错误。它依赖特征库。
NIDS 一定能分析加密数据内容	错误。NIDS 无法分析加密数据。

计算题与公式题专项作答模板

计算点	公式/规则	答题模板
ALE/SLE/ROSI	SLE=AV×EF；ALE=SLE×ARO=AV×EF×ARO；ROSI=实施控制前 ALE−实施控制后 ALE−年控制成本。	先解释变量，再代入计算，最后判断控制措施是否有成本效益。
PPDR 时间	Pt>Dt+Rt 表示安全；若 Pt<Dt+Rt，则 Et=(Dt+Rt)−Pt。	先判断防护时间能否覆盖检测和响应时间，再给出暴露时间。
风险相乘法	风险值=可能性×影响。	根据题干给出的等级赋值计算风险值，再按预设等级表判定风险等级。
资产价值最大原则	VA=Max(VAc, VAi, VAa, VAac, VAn)。	取机密性、完整性、可用性、可审计性、不可抵赖性等属性中最高值。
资产价值加权原则	VA=VAc·Wc+VAi·Wi+VAa·Wa+VAac·Wac+VAn·Wn，权重和为 1。	先列属性赋值和权重，再乘权求和。
对称密钥数量	n 个用户两两安全通信需要 n(n−1)/2 个密钥。	用于说明对称密钥体制存在密钥分发问题。
零知识证明概率	不知道秘密仍连续猜中 n 轮的概率为 1/2^n。	轮数越多，伪装成功概率越低；例如 16 轮为 1/65536。

跨章节综合简答/应用题模板

综合 1：信息安全为什么是技术与管理共同问题？【综合简答/应用题易考】

参考答案：信息安全既有技术层面，也有管理层面。技术层面要防止外部用户非法入侵，保护系统硬件、软件和数据；管理层面要约束内部员工的教育、操作和维护行为。信息系统由人建设、使用和维护，人是最薄弱环节，因此只依赖防火墙、IDS、认证设备并不能真正保证安全。完整答案应写出 CIA 目标、技术控制、管理制度、生命周期工程和人员队伍。

综合 2：如何从风险五要素分析一个安全事件？【综合简答/应用题易考】

参考答案：答题时先确定资产，如网站、数据库、业务系统、人员或声誉；再确定威胁源和威胁行为，如攻击者利用口令攻击、漏洞利用、社会工程或拒绝服务；再说明脆弱性，如配置错误、补丁缺失、流程缺陷、维护人员意识不足；最后写影响，如机密性泄露、完整性破坏、可用性中断或名誉损失。控制措施则用于减少威胁、降低脆弱性、防护资产或降低影响。

综合 3：风险评估实施流程如何展开？【综合简答/应用题易考】

参考答案：风险评估可按准备、风险要素识别、风险分析、风险结果判定来答。准备阶段制定评估方案并选择方法；识别阶段发现资产、威胁、脆弱性和已有控制措施；分析阶段判断风险发生可能性和影响程度；结果判定阶段综合分析并确定风险等级。若问简化流程，可写准备、识别、计算、报告，并说明报告中应给出整改建议和文档记录。

综合 4：定性、定量和半定量风险分析怎样比较？【综合简答/应用题易考】

参考答案：定性分析依赖知识、经验、历史教训和专家判断，用高、中、低等等级描述风险，容易达成共识但主观性强；定量分析用金额、概率、频率等数值描述风险，便于成本效益分析和投资决策，但计算复杂、数据要求高；半定量分析把定性等级转成数值，例如可能性×影响，实际评估中经常使用，能兼顾可操作性和一定量化表达。

综合 5：为什么 PPDR 体现动态安全思想？【综合简答/应用题易考】

参考答案：PPDR 不是只强调静态防护，而是在统一安全策略下，把防护、检测和响应连成动态循环。防护提升攻击者突破系统所需时间，检测发现攻击、漏洞和异常，响应降低损害并恢复系统状态。其时间公式 Pt>Dt+Rt 说明安全目标不是“永不被攻击”，而是在防护失效前完成检测和响应，使系统维持可接受的安全状态。

综合 6：IATF 深度防御如何用于安全方案设计？【综合简答/应用题易考】

参考答案：使用 IATF 设计方案时，应把信息系统分成本地计算环境、区域边界、网络和基础设施、支撑性基础设施四个领域分别考虑。客户机、服务器和应用要加强主机安全、漏洞扫描、防病毒和文件完整性保护；区域边界要通过防火墙、入侵检测和边界控制管理进出流量；网络基础设施要保证骨干网、无线和 VPN 等安全；支撑基础设施要提供密钥管理、证书管理、审计、检测和响应。

综合 7：OSI 安全服务和机制在答题中如何避免混淆？【综合简答/应用题易考】

参考答案：安全服务回答“要提供什么安全能力”，包括鉴别、访问控制、数据机密性、数据完整性和抗抵赖；安全机制回答“用什么技术手段实现这些能力”，包括加密、数字签名、访问控制、完整性机制、鉴别交换、业务流填充、路由选择控制和公证。答题时可先写服务目标，再举对应机制，例如机密性可用加密实现，抗抵赖可用数字签名和公证机制支持。

综合 8：如何设计较安全的身份鉴别方案？【综合简答/应用题易考】

参考答案：安全鉴别方案应先明确验证对象和威胁：是否要防窃听、重放、伪装、验证者被危及。普通口令简单但易泄露和被猜测；可以引入单向函数、加盐、一次性口令、质询-应答、智能卡、生物特征或双因素认证。网络环境下鉴别信息不应明文传输，也不应可重复使用。高安全场景可引入可信第三方或证书机制。

综合 9：零知识证明题怎样写出关键点？【综合简答/应用题易考】

参考答案：零知识证明要求证明者在不泄露秘密的情况下，让验证者相信其具备某种能力。答案至少包括三点：完备性，即真实证明者能够通过验证；合理性，即不知道秘密者难以冒充；零知识，即验证者只知道证明者具备能力，不获得秘密本身。山洞问题中，证明者多轮按验证者随机要求从指定出口出来，伪装成功概率随轮数增加而快速降低。

综合 10：如何用访问控制模型解决不同安全目标？【综合简答/应用题易考】

参考答案：如果目标是灵活授权和普通商业系统，可考虑 DAC，但要注意权限传递和特洛伊木马问题；如果目标是高安全等级和严格信息流控制，可考虑 MAC；如果目标是大型组织按岗位授权，可考虑 RBAC。若具体目标是防泄密，可用 BLP 的下读/上写；若目标是防止低可信数据污染高价值数据，可用 Biba 的上读/下写。

综合 11：RBAC 应用题如何答完整？【综合简答/应用题易考】

参考答案：RBAC 应用题应按用户、角色、权限、会话四步写。先识别组织岗位并定义角色，再把操作和客体组合成权限，然后把权限分配给角色，把用户分配给角色。用户登录后建立会话并激活授权角色，才能访问资源。对于重要业务，应补充角色互斥、角色基数限制、静态/动态责任分离，避免一个用户同时完成相互冲突的操作。

综合 12：防火墙选型题怎样按场景作答？【综合简答/应用题易考】

参考答案：先识别流量特点：若只是限制端口、协议和 IP，包过滤速度快、适合粗粒度控制；若要判断报文是否属于合法连接，状态检测更合适；若要审计 URL、阻断敏感文件上传或理解应用内容，应用代理或 WAF 更合适；若要综合网络层、会话层和应用层内容分析，可考虑完全内容检测。最后说明任何单一防火墙都有局限，需要日志、IDS、分区和管理配合。

综合 13：校园或企业 DMZ 设计题怎样展开？【综合简答/应用题易考】

参考答案：DMZ 设计要写出外网、DMZ、内网三类区域及其访问关系。外部用户只允许访问 DMZ 中公开服务器的指定服务，如 Web、邮件或 FTP；内部用户按策略访问 Internet 或 DMZ；外部用户不得直接访问内网核心数据库、OA、财务和研发系统。可通过防火墙规则、NAT/MAP、日志审计、内部路由器隔离和堡垒主机来实现。

综合 14：防火墙局限题为什么不能只写“防火墙没用”？【综合简答/应用题易考】

参考答案：正确答案应强调防火墙有价值但不是完整安全体系。它能实施边界访问控制、过滤数据、记录日志、隐藏内部地址、提供 NAT/VPN 等，但对内部攻击、绕过防火墙的连接、开放端口中的恶意内容、应用层复杂攻击、配置错误和主机漏洞有限。因此应与 IDS、WAF、主机加固、访问控制、审计、补丁和人员管理结合。

综合 15：WAF 应用题怎样说明传统防火墙不足？【综合简答/应用题易考】

参考答案：传统包过滤主要看 IP、端口和协议，状态检测主要看连接状态，它们不一定理解 Web 应用层语义，因此对 SQL 注入、异常 URL、恶意请求内容、敏感文件上传等 Web 应用攻击识别不足。WAF 部署在 Web 服务器前，通过代理、特征识别、自学习、异常检测等方式检查 HTTP/HTTPS 应用内容，更适合 Web 应用防护，但也要注意性能、误报、HA 和 Bypass。

综合 16：IDS 在深度防御中的位置如何说明？【综合简答/应用题易考】

参考答案：深度防御中，防火墙等措施主要承担预防和边界控制，但攻击仍可能因设计缺陷、实现缺陷、内部威胁或隧道技术发生。IDS 负责检测入侵，通过采集网络流量、系统日志、文件完整性、进程行为等信息，分析异常或已知特征，发现违反策略的行为，并通过报警、终止连接、断开链路、引入陷阱或联动防火墙响应。

综合 17：异常检测和特征检测如何结合使用？【综合简答/应用题易考】

参考答案：异常检测适合发现未知攻击，因为它关注行为是否偏离正常模式，但误报率高、正常模型难建立；特征检测适合发现已知攻击，准确率高、算法简单，但依赖特征库更新且难以发现新攻击。实际部署中可以把二者结合：特征检测用于稳定识别已知攻击，异常检测用于发现未知或可疑行为，再由人工和日志审计进一步分析。

综合 18：HIDS/NIDS 部署题如何根据位置说明价值？【综合简答/应用题易考】

参考答案：HIDS 部署在主机上，可查看系统日志、文件系统和进程记录，适合定位具体用户和加密环境；NIDS 部署在网络关键位置，可实时监控网络攻击但不能看加密内容。若放在边界前后，可观察互联网攻击和防火墙效果；放在 DMZ，可分析公开服务器受攻击情况；放在网络中枢，可发现内网越权和横向移动；放在高安全子网，可重点保护关键资产。

综合 19：IDS 选型指标怎样解释？【综合简答/应用题易考】

参考答案：选择 IDS 不能只看功能清单，还要考虑准确性、处理性能、完备性、容错性和及时性。准确性与误报率相关，误报过多会增加管理员负担；完备性与漏报率相关，漏报会导致攻击未被发现；处理性能决定能否跟上网络或主机数据源速度；容错性体现 IDS 自身抗攻击能力；及时性要求尽快分析并传播结果，以便在损害扩大前响应。

综合 20：安全建设案例题如何从“风险—控制—验证”答？【综合简答/应用题易考】

参考答案：先识别资产和业务使命，例如网站、数据库、账户、服务器或核心业务；再识别威胁和脆弱性，例如口令攻击、漏洞利用、配置错误、权限过大或内部滥用；然后选择控制措施，如补丁、加密、鉴别、访问控制、防火墙、IDS、备份、应急响应和培训；最后说明通过风险评估、监控审查、日志审计、测评和应急演练验证安全效果。

综合 21：为什么“适度安全”比“绝对安全”更符合课程思想？【综合简答/应用题易考】

参考答案：风险管理强调把风险降低到可接受水平，而不是消除一切风险。安全投入、便利性和业务目标之间存在矛盾，如果无限追求安全，可能导致成本过高或业务不可用；如果只追求方便，又会放大威胁和脆弱性。适度安全要求根据资产价值、威胁可能性、影响程度和成本效益来确定控制措施，并持续监控残余风险。

综合 22：生命周期中的安全工作如何分阶段说明？【综合简答/应用题易考】

参考答案：规划阶段要明确总体安全方针、安全需求和风险评估准则；设计阶段要论证安全设计方案，选择安全技术和产品，处理自开发软件风险；实施阶段要采购、开发、集成、配置、测试安全机制，并培训人员、授权系统运行；运维阶段要进行安全运行、变更管理、风险再评估和定期审批；废弃阶段要确定废弃对象、评估废弃风险并安全报废。

综合 23：如何把“人是最薄弱环节”写成应用题答案？【综合简答/应用题易考】

参考答案：可以写：攻击者不一定直接突破高强度技术设备，也可能通过社会工程、钓鱼邮件、电话诱骗、默认口令、弱口令、权限滥用、U 盘使用和操作失误突破防线。因此安全建设要包括人员安全意识培训、岗位职责划分、授权复查、口令策略、操作审批、日志审计和违规追责。技术设备用于防护，管理制度用于约束人，二者缺一不可。

综合 24：国产化替代题如何写出“不只是换设备”？【综合简答/应用题易考】

参考答案：国产化替代的核心是自主可控和安全可控，不只是把国外品牌换成国内品牌。答题应说明替代对象包括被国外企业垄断的芯片、CPU 架构、操作系统、数据库、中间件、高端服务器和相关软硬件生态；目标是降低关键领域对外依赖，增强核心技术掌控能力。还应补充信创产业从云计算、软件、硬件、安全等方面推动信息技术应用创新。

综合 25：安全需求 ISPP 和安全目标 ISST 怎样区分？【综合简答/应用题易考】

参考答案：ISPP 是信息系统保护轮廓，从信息系统所有者或用户角度规范化、结构化描述某类信息系统的安全保障需求和能力，强调与实现无关的系统级安全要求；ISST 是信息系统安全目标，从建设方或厂商角度根据信息系统保护轮廓编制安全保障方案，描述某一特定产品或系统的安全需求和概要规范。答题可用“用户提需求，建设方给方案”区分。

综合 26：等级保护、风险评估和安全测评怎样联系？【综合简答/应用题易考】

参考答案：等级保护强调按国家制度对重要网络和信息系统进行分等级保护，安全测评是在既定安全基线或标准基础上检查符合性，风险评估则面向被评估系统的特定安全需求识别、分析和评价风险。答题时可写：等保和安全检查偏符合性，风险评估偏风险识别和排序，三者共同服务于网络空间安全建设和管理。

综合 27：灾难恢复为什么是最后一道防线？【综合简答/应用题易考】
参考答案：灾难恢复用于保持业务连续运作，是对现有信息系统安全保护的延伸。当前面的预防、检测、响应措施无法完全避免事故时，灾难备份、恢复计划和业务连续性措施能够降低安全事件造成的影响，帮助系统恢复功能和数据。答题时要强调它不是替代防护，而是在事故发生后减少损失、保障长期可持续运行。

综合 28：访问控制与 AAA 如何联系？【综合简答/应用题易考】
参考答案：访问控制常与鉴别、授权、审计联系在一起，即 AAA。鉴别用于确认主体身份，是访问控制的前提；授权用于规定主体能对哪些客体执行什么操作；审计用于记录主体行为并追踪责任。一个完整访问控制过程通常是先鉴别身份，再依据授权策略进行决策和执行，最后通过日志审计发现违规或追责。

综合 29：自主访问控制为什么灵活但安全性不高？【综合简答/应用题易考】
参考答案：DAC 允许客体属主决定访问权限，主体可以根据需要把访问权的子集授予其他主体，因此灵活性高、易用性好，常用于商业系统。但它无法有效控制信息流动，权限在信息移动过程中可能被改变；还可能受到特洛伊木马威胁，合法用户运行的恶意程序可能利用用户权限执行非法操作。因此 DAC 适合灵活授权场景，但不适合严格保密场景。

综合 30：强制访问控制为什么适合高安全系统？【综合简答/应用题易考】
参考答案：MAC 中主体和客体分配固定安全级别或安全标签，访问请求必须按照强制策略控制，客体属主无权随意改变权限。它通过安全级别和访问规则控制信息流方向，适合军事等高安全要求系统。其优点是安全性强、能防止越权和非法信息流动；缺点是控制粒度较大、灵活性较低，实际系统中可与 DAC 结合使用。

综合 31：防火墙 NAT 和 MAP 功能如何用于隐藏内部结构？【综合简答/应用题易考】
参考答案：NAT 通过把内部私有地址转换为防火墙外部地址访问互联网，隐藏内部主机真实地址和网络结构，也能缓解公开地址不足问题。MAP 地址/端口映射可把外部访问某公网地址和端口映射到内部服务器的私有地址和端口，使公开服务器可使用私有地址。答题时要写出：NAT 偏内网出网，MAP 偏外网访问内部公开服务。

综合 32：防火墙路由模式和透明模式如何区分？【综合简答/应用题易考】
参考答案：路由模式工作在第三层，防火墙各接口配置不同网段 IP 地址，相当于路由器，需要重新规划网络拓扑；透明模式工作在第二层链路层，防火墙对用户和路由器基本透明，像网桥一样接入网络，通常不需要修改现有主机网关和路由配置。若题目强调“不改变原网络结构”，通常选择透明模式。

综合 33：高可用性在防火墙中如何体现？【综合简答/应用题易考】
参考答案：防火墙高可用性可通过双机热备实现。正常情况下主防火墙工作，备用防火墙通过心跳线检测主防火墙状态；当主防火墙故障时，备用防火墙立即接管工作，用户连接尽量透明迁移。服务器负载均衡则可根据轮流、轮流加权、最少连接、最少连接加权等算法把请求分配到服务器阵列，提高服务可用性和性能。

综合 34：CIDF 通用模型四组件如何写？【综合简答/应用题易考】
参考答案：CIDF 把入侵检测系统需要分析的数据统称为事件，事件可以来自网络数据包，也可以来自系统日志。其逻辑组件包括事件生成器、事件分析器、事件数据库、事件响应器。事件生成器采集和监视数据；事件分析器识别非法或异常现象；事件数据库保存原始事件和分析结果；事件响应器在发现入侵企图时执行告警、拦截、阻断或反追踪等动作。

综合 35：Denning 模型中审计记录和活动剖面如何展开？【综合简答/应用题易考】
参考答案：Denning 模型的审计记录格式为<Subject, Action, Object, Exception-Condition, Resource-Usage, Time-Stamp>，分别表示活动发起者、操作、承受者、异常报告、资源消耗和时间。活动剖面保存主体正常行为信息，随机变量包括事件计数器、间隔计时器和资源计量器。模型通过规则集处理引擎比较审计记录与活动剖面，发现异常时生成异常记录并响应。

综合 36：SNMP-IDSM 为什么能支持 IDS 协同？【综合简答/应用题易考】
参考答案：SNMP-IDSM 从网络管理角度出发，把 SNMP 作为公共语言来实现不同 IDS 之间的信息交换和协同检测。它定义 IDS-MIB，使原始事件和抽象事件之间的关系更明确，也便于扩展。攻击事件可用 where、when、who、what、how 描述，分别说明攻击位置、时间、检测事件、详细协议信息和原始/抽象事件之间的联系。

综合 37：Snort 规则如何拆分为规则头和规则选项？【综合简答/应用题易考】
参考答案：Snort 规则由规则头和规则选项组成。规则头通常包括动作、协议、源/目的 IP、端口和方向操作符，例如 alert、log、pass 等动作；规则选项放在括号中，用分号分隔，用冒号连接关键字和参数，常见关键字包括 msg、flags、dsize、content、resp、sid、classtype、priority、rev 等。答题可举 alert icmp any any -> $HOME_NET any 作为结构示例。

综合 38：IDS 误报率和漏报率如何评价？【综合简答/应用题易考】
参考答案：误报率是把正常事件识别为攻击并报警，误报过高会增加管理员负担、降低告警可信度；漏报率是攻击事件没有被检测到，漏报会导致真实攻击被放过。选择 IDS 时还要考虑准确性、处理性能、完备性、容错性和及时性，不能只看告警数量。一个好的 IDS 应尽量降低误报和漏报，并能及时分析和传播结果。

综合 39：如何把“信息泄露事件”写成风险处置答案？【综合简答/应用题易考】

参考答案：先把被泄露的数据、系统和声誉确定为资产；再分析威胁源可能是外部攻击者、内部人员或第三方；威胁行为可能是漏洞利用、口令攻击、越权访问或社会工程；脆弱性可能是默认口令、未打补丁、权限过大、审计不足或培训不到位。处置可包括减低风险，如补丁、权限复查、加密、审计和 IDS；也可通过保险或外包转移部分风险，对高敏信息不进入低安全系统则属于规避。

综合 40：如何说明“安全策略”在 PPDR 中的核心地位？【综合简答/应用题易考】
参考答案：PPDR 中的 Policy 是模型核心，防护、检测、响应都要在安全策略指导下实施。策略可以包括访问控制策略、加密通信策略、身份认证策略、备份恢复策略等。没有策略，防火墙规则、IDS 告警和响应动作就缺乏统一依据；策略不合理，技术措施也可能允许高风险流量或阻断正常业务。因此 PPDR 不是设备堆叠，而是以策略统领动态防御。

综合 41：如何比较防火墙和访问控制？【综合简答/应用题易考】
参考答案：访问控制是防止主体越权访问客体的安全机制，既可发生在系统、文件、数据库、应用等内部资源上，也可体现在网络访问上；防火墙是一种高级访问控制设备，置于不同网络安全域之间，通过安全策略控制进出网络的数据流。可以说防火墙是网络边界层面的访问控制实现，但访问控制的范围比防火墙更广。

综合 42：如何回答“为什么状态检测性能通常优于代理防火墙”？【综合简答/应用题易考】
参考答案：状态检测防火墙首包严格检查，合法后把连接写入状态表，后续报文可快速查表判断，避免每个报文都进行复杂应用层代理处理。代理防火墙需要替代通信双方在应用层建立连接并检查内容，安全控制更细，但处理开销大、速度较慢。状态检测的优势在于把“每包重复匹配”变成“首包严查+后续查表”，兼顾连接合法性和处理性能。

综合 43：如何分析“内部横向移动”问题？【综合简答/应用题易考】
参考答案：内部横向移动说明只有边界防火墙不够。攻击者一旦通过第三方账号、钓鱼或终端木马进入内网，若普通业务区与支付系统、数据库或高价值资产隔离不足，就可能继续扩展权限和访问范围。应通过内网分区、访问控制、DMZ、最小权限、日志审计、IDS 部署和关键系统隔离限制横向移动，把高价值资产与普通网络严格隔开。

综合 44：如何说明“日志审计”的价值？【综合简答/应用题易考】
参考答案：日志审计用于记录访问行为、通信源目的地址、端口、协议、时间、字节数、是否允许通过，以及应用层命令和内容等。它可以帮助管理员判断异常、追踪责任、发现攻击和评估策略效果。没有日志，即使攻击发生也难以还原过程；有日志但不分析，也难以及时发现问题。因此日志审计应与告警、报表和安全响应结合。

综合 45：如何回答“鉴别信息为什么不能重复使用”？【综合简答/应用题易考】
参考答案：网络中的鉴别信息如果可以重复使用，攻击者通过窃听得到后就能重放给验证者，冒充合法用户。因此网络上传输的鉴别信息不可重用。解决方法包括一次性口令、随机数、时间戳、计数器、密码链和质询-应答机制。质询-应答由验证者产生非重复质询，声称者用秘密信息计算响应，使每次传输的鉴别结果不同。

综合 46：如何把“最小特权原则”用于访问控制应用题？【综合简答/应用题易考】
参考答案：最小特权原则要求用户和代表用户的进程只拥有完成职责所需的最小权限，系统不应授予超过任务需要的特权。应用题中可写：普通用户只读必要资料，管理员权限分离，审计员可读但不可修改，系统管理员可开关系统但不读改用户账户数据。这样可减少误操作、权限滥用和恶意程序利用过大权限造成的损害。

综合 47：如何说明“异常检测误报高”的原因？【综合简答/应用题易考】
参考答案：异常检测先建立正常行为模型，再把偏离模型的行为判定为可疑。但现实中合法用户的正常行为会变化，业务高峰、临时任务、系统升级都可能造成行为偏离；同时“正常”和“异常”边界本身难以精确划分。因此异常检测能够发现未知攻击，但容易误报，也可能被攻击者通过逐渐改变行为模式绕过。

综合 48：如何说明“特征库更新”对 IDS 的重要性？【综合简答/应用题易考】
参考答案：特征检测依赖已知攻击方法和攻击特征库，把当前行为与已知模式匹配。特征库越完整、越准确，IDS 越能识别已知攻击；如果特征库过旧，新的漏洞利用、变形攻击或未知攻击就可能无法检测。同时要注意特征库是否完整、准确对 IDS 检测能力具有决定性影响，因此部署 IDS 后还要持续更新规则和优化感应器。

综合 49：如何回答“安全事件响应有哪些方式”？【综合简答/应用题易考】
参考答案：IDS 发现入侵后可在控制台显示告警，通过电子邮件通知管理员，按预先规则阻断连接，IDS 自身阻断，或与防火墙联动阻断攻击流量。响应还可包括终止连接、断开链路、引入陷阱等。需要提醒的是，要采取事件归并，防止响应机制被攻击者利用导致拒绝服务。完整答案应写出告警、阻断、联动和防滥用。

综合 50：如何把“木桶原理”和“深度防御”结合答题？【综合简答/应用题易考】
参考答案：木桶原理说明整体安全由最薄弱环节决定，深度防御说明不能依靠单一防线。应用题中可写：边界防火墙、防病毒、补丁、鉴别、访问控制、日志审计、IDS、备份恢复、制度培训和应急响应都要配合，任何一个短板都可能成为突破口。安全建设应通过多层防护和持续监控减少单点失效，把风险控制在可接受水平。

综合 51：安全方案题如何体现“分层防护”？【综合简答/应用题易考】
参考答案：分层防护题可把措施分为物理层、系统层、网络层、应用层和管理层。物理层保护机房、线路、电源和设备；系统层处理操作系统漏洞、配置和病毒；网络层使用防火墙、访问控制、VPN、IDS 和路由安全；应用层关注 Web、邮件、数据库和内容安全；管理层通过制度、岗位、培训、审计和应急响应保障措施落地。这样答能体现课程中“技术体系+组织管理”的整体思想。

综合 52：期末应用题如何写出“为什么不用其他方案”？【综合简答/应用题易考】

参考答案：应用题不能只写“采用某技术”，还要说明适用理由和其他方案不足。例如学校出口只需按 IP/端口快速拦截扫描，可用包过滤；若要识别伪造连接和返回流量，应选状态检测；若要审计 URL 和阻断敏感文件上传，应选代理或 WAF；若要发现已经发生的攻击，应部署 IDS。这样作答能体现对技术边界和场景需求的理解。